

**ЧАСТНОЕ УЧРЕЖДЕНИЕ ДОПОЛНИТЕЛЬНОГО
ПРОФЕССИОНАЛЬНОГО ОБРАЗОВАНИЯ
«РЕГИОНАЛЬНЫЙ ЦЕНТР БЕЗОПАСНОСТИ»**

390010, г. Рязань, ул. Новикова-Прибоя, дом 10, тел. (4912) 38-82-08, 38-76-96 .E-mail:rcb@rcbrzn.ru

МЕТОДИЧЕСКИЕ РЕКОМЕНДАЦИИ

по написанию документа «Модель угроз и нарушителей безопасности
информации»

Рязань 2021

Оглавление

ВВЕДЕНИЕ	6
1. Структура модели угроз безопасности информации	7
2. Раздел «Перечень принятых сокращений»	10
3. Раздел «Термины и их определения»	10
4. Раздел « Общие положения»	11
4.1. Подраздел «Назначение и область действия документа»	11
4.2. Подраздел «Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз»	11
4.3. Подраздел «Наименование обладателя информации, заказчика, оператора систем и сетей»	12
4.4. Подраздел «Подразделения, должностные лица, ответственные за обеспечение защиты информации (безопасности) систем и сетей»	13
4.5. Подраздел «Наименование организации, привлекаемой для разработки модели угроз безопасности информации (при наличии)»	13
5. Раздел «Описание систем и сетей и их характеристика как объектов защиты»	13
5.1. Подраздел «Наименование систем и сетей, для которых разработана модель угроз безопасности информации»	13
5.2. Подраздел «Класс защищенности, категория значимости систем и сетей, уровень защищенности персональных данных	13
5.3. Подраздел «Нормативные правовые акты Российской Федерации, в соответствии с которыми создаются и (или) функционируют системы и сети»	14
5.4. Подраздел «Назначение, задачи (функции) систем и сетей, состав обрабатываемой информации и ее правовой режим»	15

5.5. Подраздел «Основные процессы (бизнес-процессы) обладателя информации, оператора, для обеспечения которых создаются (функционируют) системы и сети»	16
5.6. Подраздел «Состав и архитектуру систем и сетей, в том числе интерфейсы и взаимосвязи компонентов систем и сетей»	16
5.7. Подраздел «Описание групп внешних и внутренних пользователей систем и сетей, уровней их полномочий и типов доступа.....	17
5.8. Подраздел «Описание внешних интерфейсов и взаимодействий систем и сетей с пользователями (в том числе посредством машинных носителей информации, средств ввода-вывода, веб-приложений), иными системами и сетями, обеспечивающими системами, в том числе с сетью «Интернет»	17
5.9. Подраздел «Информация о функционировании систем и сетей на базе информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры	18
6. Раздел « Возможные негативные последствия от реализации (возникновения) угроз безопасности информации».....	19
6.1. Подраздел «Описание видов рисков (ущербов), актуальных для обладателя информации, оператора, которые могут наступить от нарушения или прекращения основных процессов».....	21
6.2. Подраздел «Описание негативных последствий, наступление которых в результате реализации (возникновения) угроз безопасности информации может привести к возникновению рисков (ущерба)»	22
7. Раздел «Возможные объекты воздействия угроз безопасности информации»	26
7.1. Подраздел «Наименования и назначение компонентов систем и сетей, которые непосредственно участвуют в обработке и хранении защищаемой информации, или обеспечивают реализацию основных процессов обладателя информации, оператора»	27

7.2. Подраздел «Описание видов воздействия на компоненты систем и сетей, реализация которых нарушителем может привести к негативным последствиям»	29
8. Раздел «Источники угроз безопасности информации»	34
8.1. Подраздел «Характеристика нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации»	36
8.2. Подраздел «Категории актуальных нарушителей, которые могут являться источниками угроз безопасности информации»	39
8.3. Подраздел «Описание возможностей нарушителей по реализации ими угроз безопасности применительно к назначению, составу и архитектуре систем и сетей»	42
9. Раздел «Способы реализации (возникновения) угроз безопасности информации»	49
9.1. Подраздел «Описание способов реализации (возникновения) угроз безопасности информации, которые могут быть использованы нарушителями разных видов и категорий»	51
9.2. Подраздел «Описание интерфейсов объектов воздействия, доступных для использования нарушителями способов реализации угроз безопасности информации»	52
10. Раздел «Актуальные угрозы безопасности информации»	58
10.1. Подраздел «Перечень возможных (вероятных) угроз безопасности информации для соответствующих способов их реализации и уровней возможностей нарушителей»	59
10.2. Подраздел «Описание возможных сценариев реализации угроз безопасности информации»	59

10.4. Подраздел «Выводы об актуальности угроз безопасности информации»	80
11. Раздел «Определение актуальности использования СКЗИ и угроз, нейтрализуемых только с помощью СКЗИ»	84
11.1. Подраздел «Определение актуальности использования СКЗИ для обеспечения безопасности информации»	85
11.2. Подраздел «Определение актуальности угроз, нейтрализуемых только с помощью СКЗИ»	89
12. Раздел «Выводы»	103

ВВЕДЕНИЕ

Настоящие методические рекомендации разработаны на основе методического документа ФСТЭК России «Методика оценки угроз безопасности информации», утвержденного 05.02.2021, методического документа ФСБ России «Методические рекомендации по разработке нормативных правовых актов, определяющих угрозы безопасности персональных данных, актуальные при обработке персональных данных в информационных системах персональных данных, эксплуатируемых при осуществлении соответствующих видов деятельности».

Данный документ устанавливает единый методический подход к определению угроз безопасности информации и разработке моделей угроз безопасности информации в государственных информационных системах, защита информации в которых обеспечивается в соответствии с Требованиями о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах, утвержденными приказом ФСТЭК России от 11 февраля 2013 г. № 17, а также применяется для определения угроз безопасности персональных данных при их обработке в информационных системах персональных данных, защита которых обеспечивается в соответствии с Составом и содержанием организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных, утвержденных приказом ФСТЭК России от 18 февраля 2013 г. № 21, применяется также для определения угроз безопасности информации, реализация (возникновение) которых возможна в системах и сетях, отнесенных значимым объектам критической информационной инфраструктуры Российской Федерации.

1. Структура модели угроз безопасности информации

Модель угроз безопасности информации должна содержать следующие разделы:

1. Перечень принятых сокращений
2. Термины и их определения
3. Общие положения
 - 3.1. Назначение и область действия документа;
 - 3.2. Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз;
 - 3.3. Наименование обладателя информации, заказчика, оператора систем и сетей;
 - 3.4. Подразделения, должностные лица, ответственные за обеспечение защиты информации (безопасности) систем и сетей;
 - 3.5. Наименование организации, привлекаемой для разработки модели угроз безопасности информации (при наличии);
4. Описание систем и сетей и их характеристика как объектов защиты
 - 4.1. Наименование систем и сетей, для которых разработана модель угроз безопасности информации;
 - 4.2. Класс защищенности, категория значимости систем и сетей, уровень защищенности персональных данных;
 - 4.3. Нормативные правовые акты Российской Федерации, в соответствии с которыми создаются и (или) функционируют системы и сети;
 - 4.4. Назначение, задачи (функции) систем и сетей, состав обрабатываемой информации и ее правовой режим;
 - 4.5. Основные процессы (бизнес-процессы) обладателя информации, оператора, для обеспечения которых создаются (функционируют) системы и сети;

4.6. Состав и архитектура систем и сетей, в том числе интерфейсы и взаимосвязи компонентов систем и сетей;

4.7. Описание групп внешних и внутренних пользователей систем и сетей, уровней их полномочий и типов доступа (в состав групп пользователей включаются все пользователи, для которых требуется авторизация при доступе к информационным ресурсам, и пользователи, для которых не требуется авторизация (например, предоставлен доступ к сайту без прохождения авторизации));

4.8. Описание внешних интерфейсов и взаимодействий систем и сетей с пользователями (в том числе посредством машинных носителей информации, средств ввода-вывода, веб-приложений), иными системами и сетями, обеспечивающими системами, в том числе с сетью «Интернет»;

4.9. Информация о функционировании систем и сетей на базе информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры, о модели предоставления вычислительных услуг, о распределении ответственности за защиту информации между обладателем информации, оператором и поставщиком вычислительных услуг, об условиях использования информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры поставщика услуг (при наличии).

5. Возможные негативные последствия от реализации (возникновения) угроз безопасности информации;

5.1. Описание видов рисков (ущербов), актуальных для обладателя информации, оператора, которые могут наступить от нарушения или прекращения основных процессов;

5.2. Описание негативных последствий, наступление которых в результате реализации (возникновения) угроз безопасности информации может привести к возникновению рисков (ущерба);

6. Возможные объекты воздействия угроз безопасности информации;

6.1. Наименования и назначение компонентов систем и сетей, которые непосредственно участвуют в обработке и хранении защищаемой информации, или обеспечивают реализацию основных процессов обладателя информации, оператора;

6.2. Описание видов воздействия на компоненты систем и сетей, реализация которых нарушителем может привести к негативным последствиям;

7. Источники угроз безопасности информации;

7.1. Характеристика нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации;

7.2. Категории актуальных нарушителей, которые могут являться источниками угроз безопасности информации;

7.3. Описание возможностей нарушителей по реализации ими угроз безопасности применительно к назначению, составу и архитектуре систем и сетей;

8. Способы реализации (возникновения) угроз безопасности информации;

8.1. Описание способов реализации (возникновения) угроз безопасности информации, которые могут быть использованы нарушителями разных видов и категорий;

8.2. Описание интерфейсов объектов воздействия, доступных для использования нарушителями способов реализации угроз безопасности информации;

9. Актуальные угрозы безопасности информации;

9.1. Перечень возможных (вероятных) угроз безопасности информации для соответствующих способов их реализации и уровней возможностей нарушителей;

9.2. Описание возможных сценариев реализации угроз безопасности информации;

9.3. Выводы об актуальности угроз безопасности информации.

10. Применение средств криптографической защиты информации.(при необходимости)

Выводы

Приложения (при необходимости).

На титульном листе разрабатываемой Модели угроз безопасности информации необходимо указать ссылку на Реестр государственных информационных систем, в который включена информационная система (в случае, если данная информационная система является государственной).

Модель угроз безопасности информации утверждается должностным лицом организации, являющейся собственником информационной системы или являющейся оператором информационной системы.

В случае если информационная система является государственной информационной системой, то Модель угроз безопасности информации согласуются с федеральным органом исполнительной власти в области обеспечения безопасности и федеральным органом исполнительной власти, уполномоченным в области противодействия техническим разведкам и технической защиты информации, в пределах их полномочий в части, касающейся выполнения установленных требований о защите информации.

2. Раздел «Перечень принятых сокращений»

Данный раздел содержит перечень принятых сокращений и их полное наименование, которые встречаются в разрабатываемом документе.

3. Раздел «Термины и их определения»

Данный раздел содержит термины, встречающиеся в разрабатываемом документе, и их определения.

4. Раздел « Общие положения »

4.1. Подраздел «Назначение и область действия документа»

Данный подраздел содержит назначение и область действия разрабатываемого документа. Также в данном подразделе приводится информация о возможности пересмотра разработанной Модели угроз безопасности информации.

4.2. Подраздел «Нормативные правовые акты, методические документы, национальные стандарты, используемые для оценки угроз безопасности информации и разработки модели угроз»

Данный подраздел содержит информацию об использованных для разработки Модели угроз безопасности информации нормативных и методических документах, национальных стандартах.

В данном подразделе могут приводиться следующие нормативные и методических документы:

- Федеральный закон от 27 июля 2006 г. N 149-ФЗ «Об информации, информационных технологиях и о защите информации»;
- Федеральный закон от 27.07.2006 г. № 152-ФЗ «О персональных данных» (в случае, если в информационной системе обрабатываются персональные данные);
- Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» (в случае, если в информационной системе обрабатываются персональные данные);
- Постановление Правительства РФ от 1 ноября 2012 г. N 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных» (в случае, если в информационной системе обрабатываются персональные данные);

- Постановление Правительства Российской Федерации от 6 июля 2015 года № 676 «О требованиях к порядку создания, развития, ввода в эксплуатацию, эксплуатации и вывода из эксплуатации государственных информационных систем и дальнейшего хранения содержащейся в их базах данных информации» (в случае, если информационная система является государственной);
- Приказ Федеральной службы по техническому и экспортному контролю от 11 февраля 2013 года № 17 «Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах» в случае, если информационная система является государственной);
- Базовая модель угроз безопасности персональных данных при их обработке в информационных системах персональных данных, утвержденная заместителем директора ФСТЭК России 15 февраля 2008 года;
- ГОСТ Р 56546-2015 Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем»;
- Методический документ методика оценки угроз безопасности информации, утвержденный ФСТЭК России 5 февраля 2021 г;
- Банк данных угроз безопасности информации (информационное сообщение ФСТЭК России «О банке данных угроз безопасности информации» от 6 марта 2015 г. № 240/22/879) и т.д.

4.3. Подраздел «Наименование обладателя информации, заказчика, оператора систем и сетей»

В данном подразделе указывается полное юридическое наименование организации заказчика, оператора системы. В качестве заказчика информационной системы, сети может выступать как владелец системы, так и оператор. Также в данном разделе указывается юридические адреса предприятий заказчика и оператора.

4.4. Подраздел «Подразделения, должностные лица, ответственные за обеспечение защиты информации (безопасности) систем и сетей»

В данном подразделе указывается полное наименование подразделения или должностные лица, ответственные за обеспечение защиты информации и за обработку персональных данных (в случае, если в информационной системе обрабатываются персональные данные).

4.5. Подраздел «Наименование организации, привлекаемой для разработки модели угроз безопасности информации (при наличии)»

В данном подразделе указывается полное юридическое наименование организаций, которая выполняет работы по разработке модели угроз безопасности информации, в случае, если моделирование угроз осуществляет не собственными силами владельца (оператора) информационной системы.

5. Раздел «Описание систем и сетей и их характеристика как объектов защиты»

5.1. Подраздел «Наименование систем и сетей, для которых разработана модель угроз безопасности информации»

В данном подразделе указывается общепринятыми распорядительными документами учреждения полное наименование системы, а также ее сокращенное наименование, которое будет использоваться в рамках разрабатываемой документации.

5.2. Подраздел «Класс защищенности, категория значимости систем и сетей, уровень защищенности персональных данных»

В данном подразделе в зависимости от вида информационной системы (государственная информационная, система персональных данных или информационная система является объектом критической информационной инфраструктуры Российской Федерации) указывается класс защищенности, категория значимости систем и сетей, уровень защищенности персональных данных.

В подразделе также должно приводиться основание - акт классификации информационной системы (сети) или/и категория значимости или/и уровень защищенности персональных данных

При разработке данного раздела необходимо руководствоваться нормативными документами в сфере информационной безопасности, а именно:

1. Постановление Правительства РФ от 01.11.2012 N 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных» (в случае, если в информационной системе обрабатываются персональные данные).

2. Постановление Правительства РФ от 08.02.2018 N 127 «Об утверждении Правил категорирования объектов критической информационной инфраструктуры Российской Федерации, а также перечня показателей критериев значимости объектов критической информационной инфраструктуры Российской Федерации и их значений» (в случае, если информационная система является объектом критической информационной инфраструктуры Российской Федерации).

3. Приказ ФСТЭК России от 11 февраля 2013 г. N 17 «Об утверждении требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах» в случае, если информационная система является государственной).

5.3. Подраздел «Нормативные правовые акты Российской Федерации, в соответствии с которыми создаются и (или) функционируют системы и сети»

В данном подразделе приводятся реквизиты документов, в которых указаны основания (предпосылки) на разработку информационно системы.

Например, данными документами могут являться, контракты, договоры, распоряжения, приказы и т.д.

5.4. Подраздел «Назначение, задачи (функции) систем и сетей, состав обрабатываемой информации и ее правовой режим»

В данном подразделе указывается вид автоматизируемой деятельности, в частности, необходимо указать для управления какими процессами, предназначена информационная система или сеть. Также необходимо указать перечень объектов автоматизации (объектов), на которых предполагается ее использовать.

Также в данном разделе может приводиться описание функциональных подсистем и приводится их основные характеристики и назначение, либо общее описание функций (задач), выполняемой системой.

Функциональная система является частью системы, выделенная по определенному признаку, отвечающая признаку, конкретным целям и задачам, т.е. ее выделяют с точки зрения назначения системы.

Она отражает содержательную сторону системы и специфику ее назначения, т.е. определяет способы реализации отдельных информационных процессов (процедур).

В данном разделе также указывается перечень информации, обрабатываемой в информационной системе и ее правовой режим.

В законодательстве Российской Федерации выделяют следующие правовые режимы информации - общедоступная информация и информация ограниченного доступа.

К информации ограниченного доступа могут относиться персональные данные, коммерческая тайна, служебная тайна, профессиональная тайна и другая информация, доступ к которой ограничен федеральными законами Российской Федерации.

5.5. Подраздел «Основные процессы (бизнес-процессы) обладателя информации, оператора, для обеспечения которых создаются (функционируют) системы и сети»

В данном подразделе указываются основные процессы (бизнес-процессы) обладателя информации, оператора, для обеспечения которых создаются (функционируют) системы и сети

Бизнес-процесс (процесс) - устойчивая, целенаправленная, управляемая совокупность взаимосвязанных видов деятельности, которая по определенной технологии преобразует входы в выходы, представляющие ценность для клиента.

5.6. Подраздел «Состав и архитектуру систем и сетей, в том числе интерфейсы и взаимосвязи компонентов систем и сетей»

В данном подразделе указываются состав и архитектура информационной системы (сети), а также интерфейсы и взаимосвязи компонентов систем и сетей.

Архитектура информационной системы – абстрактное понятие, определяющее из каких составных частей (элементов, компонент) состоит информационная система и как эти части между собой взаимодействуют.

Под составными частями (элементами, компонентами) информационной системы обычно понимаются программы или программные модули выполняющие отдельные относительно изолированные задачи.

Различают следующие виды архитектуры информационных систем:

По степени распределенности:

- Настольные (desktop) – все данные (БД, СУБД, клиентские приложения) хранятся на одном компьютере
- Распределенные (distributed) – компоненты распределены по нескольким компьютерам

Распределенные подразделяются на:

- Файл-серверные

- Клиент-серверные Клиент-серверные:
- Двузвенные
- Многозвенные.

Также в данном разделе необходимо указать интерфейсы и взаимосвязи компонентов информационной системы и сетей. Например, интерфейсами в информационной системе между ее компонентами могут быть внутренние сетевые интерфейсы, обеспечивающие взаимодействие (в том числе через промежуточные компоненты) с компонентами систем и сетей, имеющими внешние сетевые интерфейсы (проводные, беспроводные) и т.д.

Также в данном подразделе могут приводиться основные сетевые протоколы и технологии, используемые для взаимодействия компонентов информационной системы.

5.7. Подраздел «Описание групп внешних и внутренних пользователей систем и сетей, уровней их полномочий и типов доступа»

В данном подразделе приводится описание групп внешних и внутренних пользователей систем и сетей, уровней их полномочий и типов доступа. При этом, в состав групп пользователей включаются все пользователи, для которых требуется авторизация при доступе к информационным ресурсам, и пользователи, для которых не требуется авторизация (например, предоставлен доступ к сайту без прохождения авторизации). В данном разделе также может приводиться матрица доступов пользователей к ресурсам информационной системы (при наличии).

5.8. Подраздел «Описание внешних интерфейсов и взаимодействий систем и сетей с пользователями (в том числе посредством машинных носителей информации, средств ввода-вывода, веб-приложений), иными системами и сетями, обеспечивающими системами, в том числе с сетью «Интернет»»

В данном подразделе приводится описание внешних интерфейсов и взаимодействий систем и сетей с пользователями (в том числе посредством машинных носителей информации, средств ввода-вывода, веб-приложений), иными системами и сетями, обеспечивающими системами, в том числе с сетью «Интернет».

Внешними интерфейсами могут являться внешние сетевые интерфейсы, обеспечивающие взаимодействие с сетью «Интернет», смежными (взаимодействующими) системами или сетями (проводные, беспроводные, веб-интерфейсы, интерфейсы удаленного доступа и др.), интерфейсы для пользователей (проводные, беспроводные, веб-интерфейсы, интерфейсы удаленного доступа и др.) и т.д.

Также в данном подразделе могут приводиться основные сетевые протоколы и технологии, используемые для внешних взаимодействий информационной системы со смежными системами и пользователями.

5.9. Подраздел «Информация о функционировании систем и сетей на базе информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры»

Данный раздел разрабатывается в случае, если информационная система (сеть) функционирует на базе информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры.

В данном разделе указывается информация о информационно-телекоммуникационной инфраструктуре центра обработки данных или облачной инфраструктуры, на базе которой функционирует информационная система, также информация о модели предоставления вычислительных услуг, о распределении ответственности за защиту информации между обладателем информации, оператором и поставщиком вычислительных услуг, об условиях использования информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры поставщика услуг (при наличии).

6. Раздел « Возможные негативные последствия от реализации (возникновения) угроз безопасности информации»

.В ходе оценки угроз безопасности информации должны быть определены негативные последствия, которые могут наступить от реализации (возникновения) угроз безопасности информации.

Исходными данными для определения негативных последствий от реализации угроз безопасности информации являются:

а) общий перечень угроз безопасности информации, содержащийся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента Российской Федерации от 16 августа 2004 г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) нормативные правовые акты Российской Федерации, в соответствии с которыми создаются и функционируют системы и сети, содержащие в том числе описание назначения, задач (функций) систем и сетей, состав обрабатываемой информации и ее правовой режим;

в) документация на сети и системы (в части сведений о назначении и функциях систем и сетей, о составе и архитектуре систем и сетей);

г) технологические, производственные карты или иные документы, содержащие описание основных (критических) процессов (бизнес-процессов) обладателя информации, оператора;

д) результаты оценки рисков (ущерба), проведенной обладателем информации или оператором.

Указанные исходные данные могут быть дополнены иными документами и сведениями с учетом особенностей области деятельности, в которой функционируют системы и сети.

На основе анализа исходных данных определяются событие или группа событий, наступление которых в результате реализации (возникновения) угроз безопасности информации может привести к:

а) нарушению прав граждан;

б) возникновению ущерба в области обеспечения обороны страны, безопасности государства и правопорядка, а также в социальной, экономической, политической, экологической сферах деятельности государства;

в) возникновению финансовых, производственных, репутационных или иных рисков (видов ущерба) для обладателя информации, оператора.

Событие или группа событий определяются применительно к нарушению основных (критических) процессов (бизнес-процессов), выполнение которых обеспечивают системы и сети, и применительно к нарушению безопасности информации, содержащейся в системах и сетях.

В случае отсутствия у обладателя информации или оператора результатов оценки рисков (ущерба), возможные негативные последствия от реализации угроз безопасности информации могут определяться как на основе экспертной оценки специалистов, проводящих оценку угроз безопасности информации, так и на основе информации, представляемой профильными подразделениями или специалистами обладателя информации или оператора.

Определяемые в ходе оценки угроз безопасности информации негативные последствия должны быть конкретизированы применительно к областям и особенностям деятельности обладателя информации или оператора. Для систем и сетей обладателя информации или оператора может быть определено одно или несколько негативных последствий.

Ниже указаны примеры возможных негативных последствий от реализации (возникновения) угроз безопасности информации.

а) если оператор обрабатывает персональные данные граждан, которые в соответствии с Федеральным законом «О персональных данных» подлежат обязательной защите, одним из возможных негативных последствий от

реализации угроз безопасности информации является нарушение конфиденциальности персональных данных, в результате которого будут нарушены права субъектов персональных данных и соответствующие законодательные акты;

б) если оператор обеспечивает транспортировку нефти, одним из возможных негативных последствий от реализации угроз безопасности информации является разлив нефти из нефтепровода, повлекший наступление экологического ущерба;

в) если оператор предоставляет услуги связи, одним из возможных негативных последствий от реализации угроз безопасности информации является непредоставление услуг связи абонентам, повлекшее наступление ущерба в социальной сфере;

г) для оператора по переводу денежных средств одним из возможных негативных последствий от реализации угроз безопасности информации является хищение денежных средств, в результате которого возможны финансовые и репутационные риски.

Виды рисков (ущербов) и типовые негативные последствия, которые могут наступить от реализации (возникновения) угроз безопасности информации, приведены в приложении 4 к методическому документу «Методика оценки угроз безопасности информации», утвержденному ФСТЭК России 5 февраля 2021 г.

6.1. Подраздел «Описание видов рисков (ущербов), актуальных для обладателя информации, оператора, которые могут наступить от нарушения или прекращения основных процессов»

В данном подразделе приводятся описание видов рисков (ущербов), актуальных для обладателя информации, оператора, которые могут наступить от нарушения или прекращения основных процессов.

Типовыми рисками (ущербом) являются:

- Ущерб физическому лицу;

- Риски юридическому лицу, индивидуальному предпринимателю, связанные с хозяйственной деятельностью;
- Ущерб государству в области обеспечения обороны страны, безопасности государства и правопорядка, а также в социальной, экономической, политической, экологической сферах деятельности.

6.2. Подраздел «Описание негативных последствий, наступление которых в результате реализации (возникновения) угроз безопасности информации может привести к возникновению рисков (ущерба)»

В данном подразделе приводятся описание негативных последствий, наступление которых в результате реализации (возникновения) угроз безопасности информации может привести к возникновению рисков (ущерба).

В случае если актуален ущерб физическому лицу, то возможными негативными последствиями могут являться:

- Угроза жизни или здоровью.
- Унижение достоинства личности.
- Нарушение свободы, личной неприкосновенности.
- Нарушение неприкосновенности частной жизни.
- Нарушение личной, семейной тайны, утрата чести и доброго имени.
- Нарушение тайны переписки, телефонных переговоров, иных сообщений.
- Нарушение иных прав и свобод гражданина, закрепленных в Конституции Российской Федерации и федеральных законах.
- Финансовый, иной материальный ущерб физическому лицу.
- Нарушение конфиденциальности (утечка) персональных данных.
- «Травля» гражданина в сети «Интернет».
- Разглашение персональных данных граждан.

В случае если актуальны риски юридическому лицу, индивидуальному предпринимателю, связанные с хозяйственной деятельностью, то возможными негативными последствиями могут являться:

- Нарушение законодательства Российской Федерации.
- Потеря (хищение) денежных средств.
- Недополучение ожидаемой (прогнозируемой) прибыли.
- Необходимость дополнительных (незапланированных) затрат на выплаты штрафов (неустоек) или компенсаций.
- Необходимость дополнительных (незапланированных) затрат на закупку товаров, работ или услуг (в том числе закупка программного обеспечения, технических средств, вышедших из строя, замена, настройка, ремонт указанных средств).
- Нарушение штатного режима функционирования автоматизированной системы управления и управляемого объекта и/или процесса.
- Срыв запланированной сделки с партнером.
- Необходимость дополнительных (незапланированных) затрат на восстановление деятельности.
- Потеря клиентов, поставщиков.
- Потеря конкурентного преимущества.
- Невозможность заключения договоров, соглашений.
- Нарушение деловой репутации.
- Снижение престижа.
- Дискредитация работников.
- Утрата доверия.
- Причинение имущественного ущерба.
- Неспособность выполнения договорных обязательств.
- Невозможность решения задач (реализации функций) или снижение эффективности решения задач (реализации функций).
- Необходимость изменения (перестроения) внутренних процедур для достижения целей, решения задач (реализации функций).
- Принятие неправильных решений.

- Простой информационной системы или сети.
- Публикация недостоверной информации на веб-ресурсах организации.

- Использование веб-ресурсов для распространения и управления вредоносным программным обеспечением.

- Рассылка информационных сообщений с использованием вычислительных мощностей оператора и (или) от его имени.

- Утечка конфиденциальной информации (коммерческой тайны, секретов производства (ноу-хау) и др.)

В случае если актуален ущерб государству в области обеспечения обороны страны, безопасности государства и правопорядка, а также в социальной, экономической, политической, экологической сферах деятельности, то возможными негативными последствиями могут являться:

- Причинение ущерба жизни и здоровью людей.
- Прекращение или нарушение функционирования объектов обеспечения жизнедеятельности населения.

- Прекращение или нарушение функционирования объектов транспортной инфраструктуры.

- Прекращение или нарушение функционирования государственного органа в части невыполнения возложенной на него функции (полномочия).

- Прекращение или нарушение функционирования сети связи.
- Отсутствие доступа к государственной услуге.
- Нарушение условий международного договора Российской Федерации, срыв переговоров или подписания планируемого к заключению международного договора Российской Федерации.

- Снижение уровня дохода государственной корпорации, государственной организации или организации с государственным участием.

- Возникновение ущерба бюджетам Российской Федерации.

- Прекращение или нарушение проведения клиентами операций по банковским счетам и (или) без открытия банковского счета или операций в системно значимой кредитной организации, оператором услуг платежной инфраструктуры системно и (или) социально значимых платежных систем, системно значимой инфраструктурной организацией финансового рынка.
- Вредные воздействия на окружающую среду.
- Прекращение или нарушение функционирования пункта управления (ситуационного центра).
- Снижение показателей государственного оборонного заказа.
- Прекращение или нарушение функционирования информационной системы в области обеспечения обороны страны, безопасности государства и правопорядка.
- Нарушение законодательства Российской Федерации.
- Публикация недостоверной социально значимой информации на веб-ресурсах, которая может привести к социальной напряженности, панике среди населения и др.
- Нарушение штатного режима функционирования автоматизированной системы управления и управляемого объекта и/или процесса, если это ведет к выводу из строя технологических объектов, их компонентов.
- Нарушение общественного правопорядка, возможность потери или снижения уровня контроля за общественным правопорядком.
- Нарушение выборного процесса.
- Отсутствие возможности оперативного оповещения населения о чрезвычайной ситуации.
- Организация пикетов, забастовок, митингов и других акций.
- Массовые увольнения.
- Увеличение количества жалоб в органы государственной власти или органы местного самоуправления.

- Появление негативных публикаций в общедоступных источниках.
- Создание предпосылок к внутривнутриполитическому кризису.
- Доступ к персональным данным сотрудников органов государственной власти, уполномоченных в области обеспечения обороны, безопасности и правопорядка, высших должностных лиц государственных органов и других лиц государственных органов.
- Доступ к системам и сетям с целью незаконного использования вычислительных мощностей.
- Использование веб-ресурсов государственных органов для распространения и управления вредоносным программным обеспечением.
- Утечка информации ограниченного доступа.
- Непредоставление государственных услуг.

7. Раздел «Возможные объекты воздействия угроз безопасности информации»

В ходе оценки угроз безопасности информации должны быть определены информационные ресурсы и компоненты систем и сетей, несанкционированный доступ к которым или воздействие на которые в ходе реализации (возникновения) угроз безопасности информации может привести к негативным последствиям – объекты воздействия.

Совокупность объектов воздействия и их интерфейсов определяет границы процесса оценки угроз безопасности информации и разработки модели угроз безопасности информации.

Исходными данными для определения возможных объектов воздействия являются:

а) общий перечень угроз безопасности информации, содержащейся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента

Российской Федерации от 16 августа 2004 г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) описания векторов компьютерных атак, содержащиеся в базах данных и иных источниках, опубликованных в сети «Интернет» (CAPEC, ATT&CK, OWASP, STIX, WASC и др.);

в) документация на сети и системы (в части сведений о составе и архитектуре, о группах пользователей и уровне их полномочий и типах доступа, внешних и внутренних интерфейсах);

г) договоры, соглашения или иные документы, содержащие условия использования информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры поставщика услуг (в случае функционирования систем и сетей на базе информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры);

д) негативные последствия от реализации (возникновения) угроз безопасности информации, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. .

Указанные исходные данные могут быть дополнены иными документами и сведениями с учетом особенностей области деятельности, в которой функционируют системы и сети.

7.1. Подраздел «Наименования и назначение компонентов систем и сетей, которые непосредственно участвуют в обработке и хранении защищаемой информации, или обеспечивают реализацию основных процессов обладателя информации, оператора»

В данном подразделе приводятся наименования и назначение компонентов систем и сетей, которые непосредственно участвуют в обработке и хранении защищаемой информации, или обеспечивают реализацию основных процессов обладателя информации, оператора.

На основе анализа исходных данных и результатов инвентаризации систем и сетей определяются следующие группы информационных ресурсов и компонентов систем и сетей, которые могут являться объектами воздействия:

а) информация (данные), содержащаяся в системах и сетях (в том числе защищаемая информация, персональные данные, информация о конфигурации систем и сетей, данные телеметрии, сведения о событиях безопасности и др.);

б) программно-аппаратные средства обработки и хранения информации (в том числе автоматизированные рабочие места, серверы, включая промышленные, средства отображения информации, программируемые логические контроллеры, производственное, технологическое оборудование (исполнительные устройства));

в) программные средства (в том числе системное и прикладное программное обеспечение, включая серверы приложений, веб-приложений, системы управления базами данных, системы виртуализации);

г) машинные носители информации, содержащие как защищаемую информацию, так и аутентификационную информацию;

д) телекоммуникационное оборудование (в том числе программное обеспечение для управления телекоммуникационным оборудованием);

е) средства защиты информации (в том числе программное обеспечение для централизованного администрирования средств защиты информации);

ж) привилегированные и непривилегированные пользователи систем и сетей, а также интерфейсы взаимодействия с ними;

з) обеспечивающие системы.

Например, к основным информационным ресурсам и компонентам систем и сетей могут относиться системы хранения данных (базы данных), системы управления базами данных, веб-сайт, почтовый сервер, почтовый клиент, автоматизированное рабочее место пользователя, система управления и администрирования, контроллер домена, сетевые службы, проводные и

беспроводные каналы передачи данных, телекоммуникационное оборудование и т.д.

На этапе создания систем и сетей объекты воздействия определяются на основе предполагаемых архитектуры и условий функционирования систем и сетей, определенных на основе изучения и анализа исходных данных. В ходе эксплуатации систем и сетей, в том числе при развитии (модернизации) систем и сетей, объекты воздействия определяются для реальных архитектуры и условий функционирования систем и сетей, полученных по результатам анализа исходных данных и инвентаризации систем и сетей.

Инвентаризация систем и сетей проводится с использованием автоматизированных средств, которые позволяют определить компоненты систем и сетей, а также внешние и внутренние интерфейсы.

7.2. Подраздел «Описание видов воздействия на компоненты систем и сетей, реализация которых нарушителем может привести к негативным последствиям»

В данном подразделе приводятся описание видов воздействия на компоненты систем и сетей, реализация которых нарушителем может привести к негативным последствиям.

Для определенных информационных ресурсов и компонентов систем и сетей должны быть определены виды воздействия на них, которые могут привести к негативным последствиям. Основными видами таких воздействий являются:

- а) утечка (перехват) конфиденциальной информации или отдельных данных (нарушение конфиденциальности);
- б) несанкционированный доступ к компонентам, защищаемой информации, системным, конфигурационным, иным служебным данным;
- в) отказ в обслуживании компонентов (нарушение доступности);

г) несанкционированная модификация, подмена, искажение защищаемой информации, системных, конфигурационных, иных служебных данных (нарушение целостности);

д) несанкционированное использование вычислительных ресурсов систем и сетей в интересах решения несвойственных им задач;

е) нарушение функционирования (работоспособности) программно-аппаратных средств обработки, передачи и хранения информации.

Объекты воздействия определяются на аппаратном, системном и прикладном уровнях, на уровне сетевой модели взаимодействия, а также на уровне пользователей (рисунок 1).

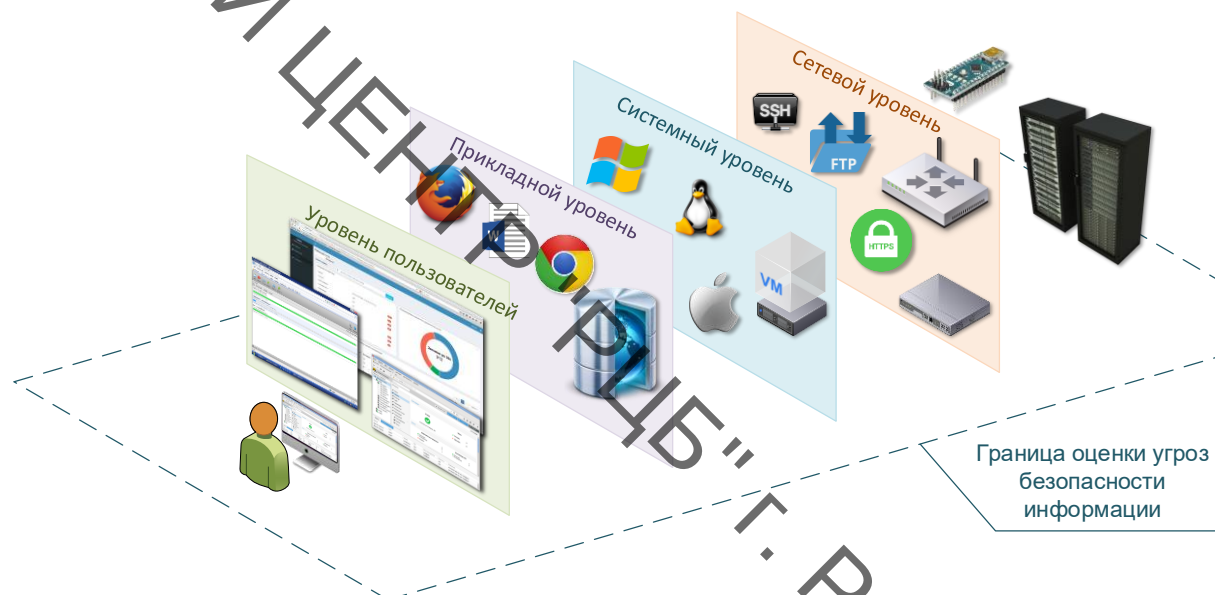


Рисунок 1. Уровни архитектуры систем и сетей, на которых определяются объекты воздействия

В процессе эксплуатации систем и сетей объекты воздействия и виды воздействия на них могут дополняться и изменяться относительно их состава и видов воздействия, определенных на этапе создания данных систем и сетей. В этом случае учет изменений должен проводиться в рамках реализации мероприятий по управлению конфигурацией систем и сетей и анализу угроз безопасности информации в ходе их эксплуатации.

При оценке угроз безопасности информации в системах и сетях, функционирующих на базе информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры, объекты воздействия определяются с учетом состава и содержания услуг, предоставляемых поставщиком услуг (например, инфраструктура как услуга, платформа как сервис, программное обеспечение как сервис).

Арендуемые или используемые на ином законном основании программно-аппаратные средства и их интерфейсы, каналы связи, программное обеспечение (в том числе программное обеспечение виртуализации и построенных на его базе виртуальных машин, виртуальных серверов, систем управления виртуализацией, виртуальных каналов связи и т.д.) относятся к объектам воздействия, находящимся в границе оценки угроз безопасности информации оператора. В отношении остальной информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры угрозы безопасности информации оцениваются поставщиком услуг.

Пример распределения границ при оценке угроз безопасности информации между оператором и поставщиком услуг представлен на рисунке 2.



Рисунок 2. Пример распределения границ при оценке угроз безопасности информации в информационной инфраструктуре поставщика услуг

Объекты воздействия и виды воздействия на них должны быть конкретизированы применительно к архитектуре и условиям функционирования систем и сетей, а также областям и особенностям деятельности обладателя информации и оператора.

Примеры определения объектов воздействия и видов воздействия на них приведены в таблице 1.

Таблица 1

Негативные последствия	Объекты воздействия	Виды воздействия
Разглашение персональных данных граждан (У1)	База данных информационной системы, содержащая идентификационную информацию граждан	Утечка идентификационной информации граждан из базы данных
	Удаленное автоматизированное рабочее место (АРМ) пользователя	Утечка идентификационной информации граждан с АРМ пользователя

	Линия связи между сервером основного центра обработки данных и сервером резервного центра обработки данных	Перехват информации, содержащей идентификационную информацию граждан, передаваемой по линиям связи
	Веб-приложение информационной системы, обрабатывающей идентификационную информацию граждан	Несанкционированный доступ к идентификационной информации граждан, содержащейся в веб-приложении информационной системы
Хищение денежных средств со счета организации (У2)	Банк-клиент	Несанкционированная подмена данных, содержащихся в реквизитах платежного поручения
	АРМ финансового директора	Несанкционированная модификация информации в платежных распоряжениях и отправка недостоверных распоряжений от имени финансового директора
	Электронный почтовый ящик финансового директора	Модификация информации в платежных распоряжениях и отправка недостоверных распоряжений от имени финансового директора
	АРМ главного бухгалтера	Подмена данных, содержащих реквизиты платежных поручений и другой платежной информации на АРМ главного бухгалтера
Срыв запланированной сделки с партнером (У2)	АРМ руководителя организации	Модификация информации и отправка электронных писем с недостоверной информацией от имени руководителя организации
	Электронный почтовый ящик руководителя организации	Модификация информации и отправка электронных писем с недостоверной информацией от имени руководителя организации
Загрязнения окружающей среды и водоемов в результате разлива нефти из нефтепровода (У3)	Коммутационный контроллер для управления аварийными задвижками в нефтепроводе	Несанкционированная модификация (изменение) логики работы или уставок коммутационного контроллера, которая приводит к открытию (или не закрытию) аварийной задвижки при нарушении герметичности нефтепровода
	Программируемый логический контроллер (ПЛК) для управления насосными станциями	Несанкционированная модификация (изменение) логики работы или уставок ПЛК, которая приводит к включению (или не отключению) насосной станции при закрытой аварийной задвижке в нефтепроводе
	АРМ оператора	Несанкционированная отправка команд, приводящая к несрабатыванию средств

		аварийной защиты и (или) к изменению логики ПЛК
Непредоставление государственных услуг (УЗ)	Веб-приложение портала государственных услуг	Отказ в обслуживании веб-приложения
	Система управления содержимым веб-приложения (сайта) портала государственных услуг	Подмена информации на страницах портала на недостоверную
	Сервер балансировки нагрузки на веб-приложение (сайт) портала государственных услуг	Отказ в обслуживании веб-приложения
	Сервер веб-приложения (сайта) портала государственных услуг	Отказ в обслуживании веб-приложения
	Сервер баз данных портала государственных услуг	Отказ в обслуживании сервера управления базами данных
		Подмена информации в базах данных на недостоверную
		Утечка персональных данных граждан

8. Раздел «Источники угроз безопасности информации»

В ходе оценки угроз безопасности информации должны быть определены возможные антропогенные источники угроз безопасности информации, к которым относятся лица (группа лиц), осуществляющие реализацию угроз безопасности информации путем несанкционированного доступа и (или) воздействия на информационные ресурсы и (или) компоненты систем и сетей, – актуальные нарушители.

Исходными данными для определения возможных актуальных нарушителей являются:

а) общий перечень угроз безопасности информации, содержащийся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента

Российской Федерации от 16 августа 2004 г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) описания векторов компьютерных атак, содержащихся в базах данных и иных источниках, опубликованных в сети «Интернет» (CAPEC, ATT&CK, OWASP, STIX, WASC и др.);

в) нормативные правовые акты Российской Федерации, в соответствии с которыми создается и функционирует система или сеть, содержащие описание назначения, задач (функций) систем и сетей, состав обрабатываемой информации и ее правовой режим;

г) документация на сети и системы (в части сведений о назначении и функциях, составе и архитектуре систем и сетей, о группах пользователей и уровне их полномочий и типах доступа, о внешних и внутренних интерфейсах);

д) договоры, соглашения или иные документы, содержащие условия использования информационно-телекоммуникационной инфраструктуры центра обработки данных или облачной инфраструктуры поставщика услуг (в части персонала поставщика услуг, имеющего доступ к этой инфраструктуре, его прав и обязанностей, уровня полномочий и типов доступа);

е) результаты оценки ущерба (рисков), проведенной владельцем информации или оператором;

ж) негативные последствия от реализации (возникновения) угроз безопасности информации, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. ;

з) объекты воздействия угроз безопасности информации и виды воздействия на них, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. .

Указанные исходные данные могут быть дополнены иными документами и сведениями с учетом особенностей области деятельности, в которой функционируют системы и сети.

8.1. Подраздел «Характеристика нарушителей, которые могут являться источниками угроз безопасности информации, и возможные цели реализации ими угроз безопасности информации»

На основе анализа исходных данных, а также результатов оценки возможных целей реализации нарушителями угроз безопасности информации определяются виды нарушителей, актуальных для систем и сетей.

Основными видами нарушителей, подлежащих оценке, являются:

- специальные службы иностранных государств;
- террористические, экстремистские группировки;
- преступные группы (криминальные структуры);
- отдельные физические лица (хакеры);
- конкурирующие организации;
- разработчики программных, программно-аппаратных средств;
- лица, обеспечивающие поставку программных, программно-аппаратных средств, обеспечивающих систем;
- поставщики услуг связи, вычислительных услуг;
- лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ;
- лица, обеспечивающие функционирование систем и сетей или обеспечивающих систем оператора (администрация, охрана, уборщики и др.);
- авторизованные пользователи систем и сетей;
- системные администраторы и администраторы безопасности;
- бывшие (уволенные) работники (пользователи).

Указанные виды нарушителей могут быть дополнены иными нарушителями с учетом особенностей области деятельности, в которой

функционируют системы и сети. Для одной системы и сети актуальными могут являться нарушители нескольких видов.

Нарушители признаются актуальными для систем и сетей, когда возможные цели реализации ими угроз безопасности информации могут привести к определенным для систем и сетей негативным последствиям и соответствующим рискам (видам ущерба). Возможные цели реализации угроз безопасности информации нарушителями приведены в приложении 6 к настоящей Методике.

Пример соответствия нарушителей, возможных целей реализации ими угроз безопасности информации и возможных негативных последствий и видов рисков (ущерба) от их реализации (возникновения) приведен в таблице 2.

Таблица 2

№ вида	Виды нарушителя	Категории нарушителя	Возможные цели реализации угроз безопасности информации
1	Специальные службы иностранных государств	Внешний	Нанесение ущерба государству в области обеспечения обороны, безопасности и правопорядка, а также в иных отдельных областях его деятельности или секторах экономики, в том числе дискредитация или дестабилизация деятельности отдельных органов государственной власти, организаций, получение конкурентных преимуществ на уровне государства, срыв заключения международных договоров, создание внутривнутриполитического кризиса
2	Террористические, экстремистские группировки	Внешний	Совершение террористических актов, угроза жизни граждан. Нанесение ущерба отдельным сферам деятельности или секторам экономики государства. Дестабилизация общества. Дестабилизация деятельности органов государственной власти, организаций
3	Преступные группы (криминальные структуры)	Внешний	Получение финансовой или иной материальной выгоды. Желание самореализации (подтверждение статуса)
4	Отдельные физические лица (хакеры)	Внешний	Получение финансовой или иной материальной выгоды.

			Любопытство или желание самореализации (подтверждение статуса)
5	Конкурирующие организации	Внешний	Получение конкурентных преимуществ. Получение финансовой или иной материальной выгоды
6	Разработчики программных, программно-аппаратных средств	Внутренний	Внедрение дополнительных функциональных возможностей в программные или программно-аппаратные средства на этапе разработки. Получение конкурентных преимуществ. Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия
7	Лица, обеспечивающие поставку программных, программно-аппаратных средств, обеспечивающих систем	Внешний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ
8	Поставщики вычислительных услуг, услуг связи	Внутренний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ
9	Лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ	Внутренний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия. Получение конкурентных преимуществ
10	Лица, обеспечивающие функционирование систем и сетей или обеспечивающие системы оператора (администрация, охрана, уборщики и т.д.)	Внутренний	Получение финансовой или иной материальной выгоды. Непреднамеренные, неосторожные или неквалифицированные действия
11	Авторизованные пользователи систем и сетей	Внутренний	Получение финансовой или иной материальной выгоды. Любопытство или желание самореализации (подтверждение статуса). Месть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия
12	Системные администраторы и	Внутренний	Получение финансовой или иной материальной выгоды.

	администраторы безопасности		Любопытство или желание самореализации (подтверждение статуса). Месть за ранее совершенные действия. Непреднамеренные, неосторожные или неквалифицированные действия
13	Бывшие работники (пользователи)	Внешний	Получение финансовой или иной материальной выгоды. Месть за ранее совершенные действия

Указанные возможные цели реализации угроз безопасности информации подлежат конкретизации и могут дополняться другими целями в зависимости от особенностей области деятельности, в которой функционируют системы и сети.

При оценке возможностей нарушителей необходимо исходить из того, что для повышения уровня своих возможностей нарушители 1 вида могут вступать в сговор с нарушителями 5, 6, 7, 8, 9, 10, 11, 12 видов. Нарушители 2 вида могут вступать в сговор с нарушителями 10, 11, 12 видов. Нарушители 3 вида могут вступать в сговор с нарушителями 10, 11, 12 видов. В случае принятия таких предположений цели и уровни возможностей нарушителей подлежат объединению.

8.2. Подраздел «Категории актуальных нарушителей, которые могут являться источниками угроз безопасности информации»

Для актуальных нарушителей должны быть определены их категории в зависимости от имеющихся прав и условий по доступу к системам и сетям, обусловленных архитектурой и условиями функционирования этих систем и сетей, а также от установленных возможностей нарушителей. При этом нарушители подразделяются на две категории (рисунок 3, 4):

внешние нарушители – нарушители, не имеющие прав доступа в контролируемую (охраняемую) зону (территорию) и (или) полномочий по доступу к информационным ресурсам и компонентам систем и сетей, требующим авторизации;

внутренние нарушители – нарушители, имеющие права доступа в контролируемую (охраняемую) зону (территорию) и (или) полномочия по автоматизированному доступу к информационным ресурсам и компонентам систем и сетей.

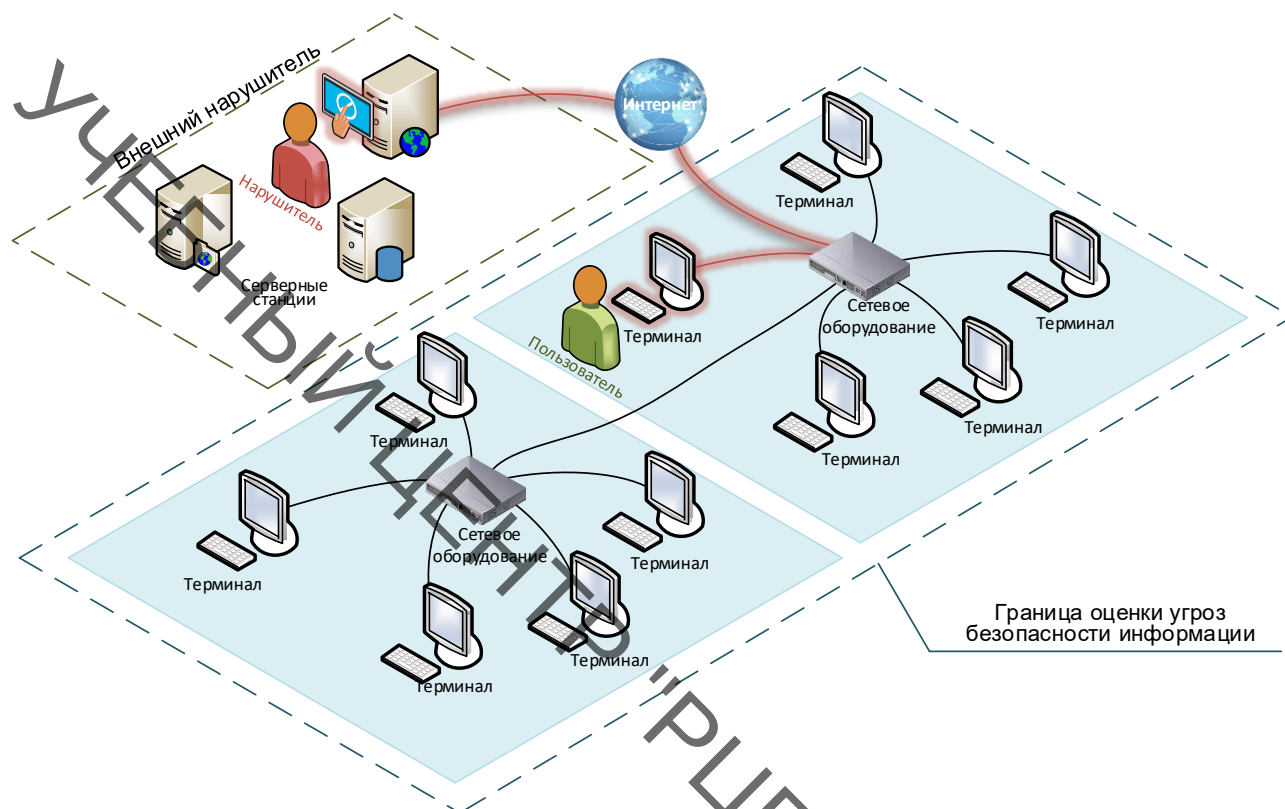


Рисунок 3. Внешний нарушитель при реализации угроз безопасности информации

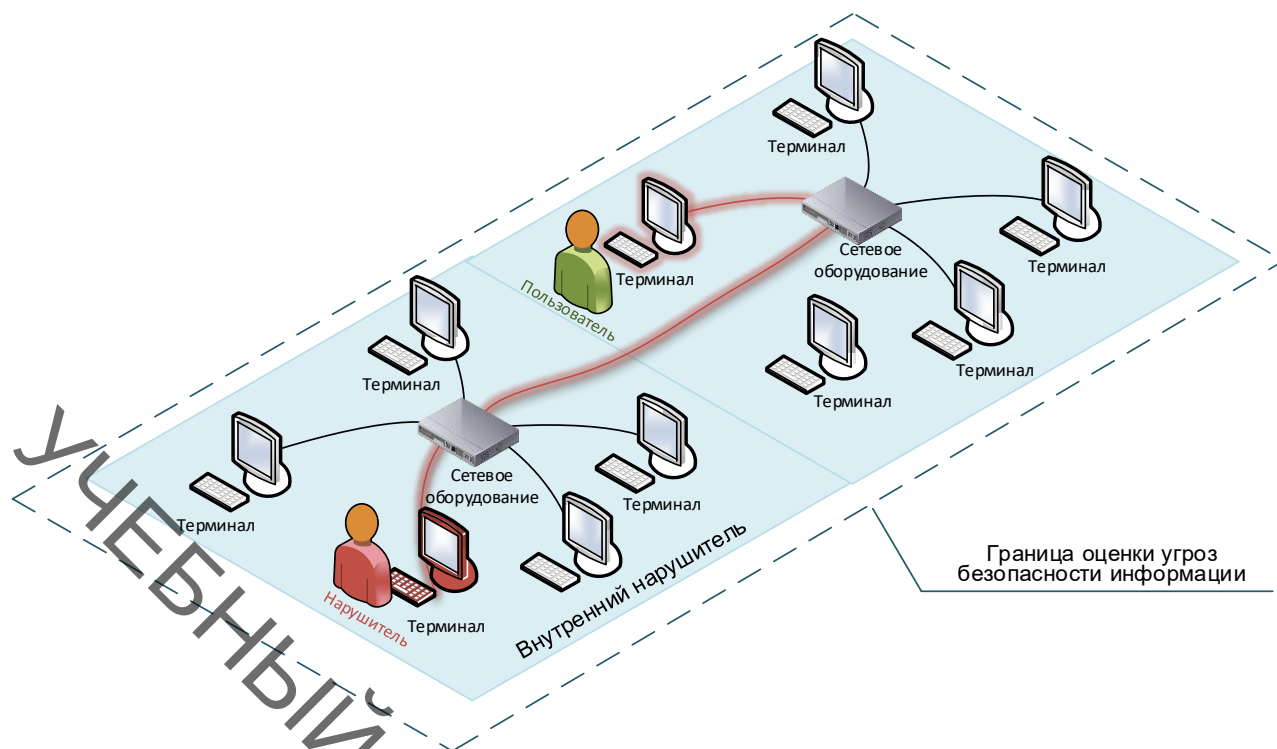


Рисунок 6. Внутренний нарушитель при реализации угроз безопасности информации

Внутренние нарушители первоначально могут иметь разный уровень прав доступа к информационным ресурсам и компонентам систем и сетей (например, доступ в личный кабинет на сайте, исполнение обязанностей на автоматизированном рабочем месте, администрирование систем и сетей). К внутренним нарушителям относятся пользователи, имеющие как непривилегированные (пользовательские), так и привилегированные (административные) права доступа к информационным ресурсам и компонентам систем и сетей.

Внешние нарушители реализуют угрозы безопасности информации преднамеренно (преднамеренные угрозы безопасности информации) с использованием программных, программно-аппаратных средств или без использования таковых. Внутренние нарушители реализуют угрозы безопасности информации преднамеренно (преднамеренные угрозы безопасности информации) с использованием программных, программно-аппаратных средств или без использования таковых или непреднамеренно

(непреднамеренные угрозы безопасности информации) без использования программных, программно-аппаратных средств.

8.3. Подраздел «Описание возможностей нарушителей по реализации ими угроз безопасности применительно к назначению, составу и архитектуре систем и сетей»

Нарушители имеют разные уровни компетентности, оснащенности ресурсами и мотивации для реализации угроз безопасности информации. Совокупность данных характеристик определяет уровень возможностей нарушителей по реализации угроз безопасности информации.

В зависимости от уровня возможностей нарушители подразделяются на нарушителей, обладающих:

базовыми возможностями по реализации угроз безопасности информации (Н1);

базовыми повышенными возможностями по реализации угроз безопасности информации (Н2);

средними возможностями по реализации угроз безопасности информации (Н3);

высокими возможностями по реализации угроз безопасности информации (Н4).

Для одной системы или сети актуальными могут являться нарушители, имеющие разные уровни возможностей.

Уровни возможностей нарушителей по реализации угроз безопасности информации приведены в таблице 3.

№	Уровень возможностей нарушителей	Возможности нарушителей по реализации угроз безопасности информации	Виды нарушителей
Н1	Нарушитель, обладающий базовыми возможностями	Имеет возможность при реализации угроз безопасности информации использовать только известные уязвимости, скрипты и инструменты. Имеет возможность использовать средства реализации угроз (инструменты), свободно распространяемые в сети «Интернет» и разработанные другими лицами, имеет минимальные знания механизмов их функционирования, доставки и выполнения вредоносного программного обеспечения, эксплойтов. Обладает базовыми компьютерными знаниями и навыками на уровне пользователя. Имеет возможность реализации угроз за счет физических воздействий на технические средства обработки и хранения информации, линий связи и обеспечивающие системы систем и сетей при наличии физического доступа к ним. Таким образом, нарушители с базовыми возможностями имеют возможность реализовывать только известные угрозы, направленные на известные (документированные) уязвимости, с использованием общедоступных инструментов	Физическое лицо (хакер) Лица, обеспечивающие поставку программных, программно-аппаратных средств, обеспечивающих систем Лица, обеспечивающие функционирование систем и сетей или обеспечивающих систем (администрация, охрана, уборщики и т.д.) Авторизованные пользователи систем и сетей Бывшие работники (пользователи)
Н2	Нарушитель, обладающий базовыми повышенными возможностями	Обладает всеми возможностями нарушителей с базовыми возможностями. Имеет возможность использовать средства реализации угроз (инструменты), свободно распространяемые в сети «Интернет» и разработанные другими лицами, однако хорошо владеет этими средствами и инструментами, понимает, как они работают и может вносить изменения в их функционирование для повышения эффективности реализации угроз. Оснащен и владеет фреймворками и наборами средств, инструментов для реализации угроз безопасности информации и использования уязвимостей.	Преступные группы (два лица и более, действующие по единому плану) Конкурирующие организации Поставщики вычислительных услуг, услуг связи Лица, привлекаемые для установки, настройки, испытаний, пусконаладочных и иных видов работ

		Имеет навыки самостоятельного планирования и реализации сценариев угроз безопасности информации. Обладает практическими знаниями о функционировании систем и сетей, операционных систем, а также имеет знания защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах. Таким образом, нарушители с базовыми повышенными возможностями имеют возможность реализовывать угрозы, в том числе направленные на неизвестные (недокументированные) уязвимости, с использованием специально созданных для этого инструментов, свободно распространяемых в сети «Интернет». Не имеют возможностей реализации угроз на физически изолированные сегменты систем и сетей	Системные администраторы и администраторы безопасности
НЗ	Нарушитель, обладающий средними возможностями	Обладает всеми возможностями нарушителей с базовыми повышенными возможностями. Имеет возможность приобретать информацию об уязвимостях, размещаемую на специализированных платных ресурсах (биржах уязвимостей). Имеет возможность приобретать дорогостоящие средства и инструменты для реализации угроз, размещаемые на специализированных платных ресурсах (биржах уязвимостей). Имеет возможность самостоятельно разрабатывать средства (инструменты), необходимые для реализации угроз (атак), реализовывать угрозы с использованием данных средств. Имеет возможность получения доступа к встраиваемому программному обеспечению аппаратных платформ, системному и прикладному программному обеспечению, телекоммуникационному оборудованию и другим программно-аппаратным средствам для проведения их анализа. Обладает знаниями и практическими навыками проведения анализа программного кода для получения информации об уязвимостях.	Террористические, экстремистские группировки Разработчики программных, программно-аппаратных средств

		Обладает высокими знаниями и практическими навыками о функционировании систем и сетей, операционных систем, а также имеет глубокое понимание защитных механизмов, применяемых в программном обеспечении, программно-аппаратных средствах. Имеет возможность реализовывать угрозы безопасности информации в составе группы лиц. Таким образом, нарушители со средними возможностями имеют возможность реализовывать угрозы, в том числе на выявленные ими неизвестные уязвимости, с использованием самостоятельно разработанных для этого инструментов. Не имеют возможностей реализации угроз на физически изолированные сегменты систем и сетей	
Н4	Нарушитель, обладающий высокими возможностями	Обладает всеми возможностями нарушителей со средними возможностями. Имеет возможность получения доступа к исходному коду встраиваемого программного обеспечения аппаратных платформ, системного и прикладного программного обеспечения, телекоммуникационного оборудования и других программно-аппаратных средств для получения сведений об уязвимостях «нулевого дня». Имеет возможность внедрения программных (программно-аппаратных) закладок или уязвимостей на различных этапах поставки программного обеспечения или программно-аппаратных средств. Имеет возможность создания методов и средств реализации угроз с привлечением специализированных научных организаций и реализации угроз с применением специально разработанных средств, в том числе обеспечивающих скрытное проникновение. Имеет возможность реализовывать угрозы с привлечением специалистов, имеющих базовые повышенные, средние и высокие возможности. Имеет возможность создания и применения специальных технических средств для добывания информации (воздействия на информацию или технические средства), распространяющейся в виде физических полей или явлений.	Специальные службы иностранных государств

		Имеет возможность долговременно и незаметно для операторов систем и сетей реализовывать угрозы безопасности информации. Обладает исключительными знаниями и практическими навыками о функционировании систем и сетей, операционных систем, аппаратном обеспечении, а также осведомлен о конкретных защитных механизмах, применяемых в программном обеспечении, программно-аппаратных средствах атакуемых систем и сетей. Таким образом, нарушители с высокими возможностями имеют практически неограниченные возможности реализовывать угрозы, в том числе с использованием недеklarированных возможностей, программных, программно-аппаратных закладок, встроенных в компоненты систем и сетей	
--	--	---	--

В случае если к системам и сетям предъявлены требования к устойчивости и надежности функционирования (в части целостности и доступности информационных ресурсов и компонентов систем и сетей), дополнительно к антропогенным источникам угроз безопасности информации в качестве актуальных могут быть определены техногенные источники (физические явления, материальные объекты). Угрозы безопасности информации, связанные с техногенными источниками, включаются в модель угроз безопасности информации по решению обладателя информации или оператора систем и сетей.

Основными факторами возникновения угроз безопасности информации, связанными с техногенными источниками, могут являться:

- а) недостатки качества, надежности программного обеспечения, программно-аппаратных средств, обеспечивающих обработку и хранение информации, их линий связи;
- б) недостатки в работе обеспечивающих систем;
- в) недоступность сервисов (услуг), предоставляемых сторонними организациями.

Возможность возникновения таких угроз определяется на основе статистики их возникновения за прошлые годы. В случае отсутствия указанной статистики возможно использование экспертной оценки.

По результатам определения источников угроз безопасности информации должны быть определены:

- а) виды актуальных нарушителей и возможные цели реализации ими угроз безопасности информации, а также их возможности;
- б) категории актуальных нарушителей, которые могут реализовывать угрозы безопасности информации, в том числе непреднамеренные угрозы.

При определении источников угроз безопасности информации необходимо исходить из предположения о наличии повышенной мотивации внешних и внутренних нарушителей, преднамеренно реализующих угрозы безопасности информации. Кроме того, необходимо учитывать, что такие

виды нарушителей как специальные службы иностранных государств и террористические, экстремистские группировки могут привлекать (входить в сговор) внутренних нарушителей, в том числе обладающих привилегированными правами доступа. В этом случае уровень возможностей актуальных нарушителей будет определяться совокупностью возможностей нарушителей, входящих в сговор.

Примеры определения актуальных нарушителей при реализации угроз безопасности информации и соответствующие им виды нарушителей и их возможности приведены в таблице 4.

Таблица 4

№ п/п	Виды риска (ущерба) и возможные негативные последствия*	Виды актуального нарушителя**	Категория нарушителя	Уровень возможностей нарушителя
1	У1: нарушение конфиденциальности персональных данных граждан; нарушение личной, семейной тайны, утрата чести и доброго имени; финансовый, иной материальный ущерб физических лиц	Преступные группы (криминальные структуры)	Внешний Внутренний***	H3
		Отдельные физические лица (хакеры)	Внешний	H2
		Разработчики программных, программно-аппаратных средств	Внутренний	H3
		Системные администраторы и администраторы безопасности	Внутренний	H2
		Авторизованные пользователи систем и сетей	Внутренний	H2
2	У2: невозможность заключения договоров, соглашений; утечка коммерческой тайны; потеря клиентов; нарушение деловой репутации; недополучение ожидаемой прибыли	Преступные группы (криминальные структуры)	Внешний	H3
		Отдельные физические лица (хакеры)	Внутренний	H2
		Разработчики программных, программно-аппаратных средств	Внутренний	H3
		Системные администраторы и администраторы безопасности	Внутренний	H2

№ п/п	Виды риска (ущерба) и возможные негативные последствия*	Виды актуального нарушителя**	Категория нарушителя	Уровень возможностей нарушителя
3	УЗ: нарушение функционирования государственного органа, дискредитация деятельности органа государственной власти; доступ к системам и сетям с целью незаконного использования вычислительных мощностей; утечка информации ограниченного доступа; организация митингов, забастовок из-за публикаций недостоверной информации; отсутствие доступа к социально значимым государственным услугам	Специальные службы иностранных государств	Внешний Внутренний***	H4
		Террористические, экстремистские организации	Внешний	H3
		Преступные группы (криминальные структуры)	Внешний Внутренний*	H3
		Разработчики программных, программно-аппаратных средств	Внутренний	H3
		Системные администраторы и администраторы безопасности	Внутренний	H3
		Авторизованные пользователи систем и сетей	Внутренний	H1
		Бывшие (уволенные) работники (пользователи)	Внутренний	H1

**- при сговоре преступной группировки (криминальной структуры) с системными администраторами и администраторами безопасности.

9. Раздел «Способы реализации (возникновения) угроз безопасности информации»

В ходе оценки угроз безопасности информации должны быть определены возможные способы реализации (возникновения) угроз безопасности информации, за счет использования которых актуальными нарушителями могут быть реализованы угрозы безопасности информации в системах и сетях, – актуальные способы реализации (возникновения) угроз безопасности информации.

Исходными данными для определения актуальных способов реализации (возникновения) угроз безопасности информации являются:

а) общий перечень угроз безопасности информации, содержащийся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента Российской Федерации от 16 августа 2004 г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) описания векторов компьютерных атак, содержащихся в базах данных и иных источниках, опубликованных в сети «Интернет» (CAPEC, ATT&CK, OWASP, STIX, WASC и др.);

в) документация на системы и сети (в части сведений о составе и архитектуре, о группах пользователей и их типах доступа и уровней полномочий, о внешних и внутренних интерфейсах);

г) негативные последствия от реализации (возникновения) угроз безопасности информации, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. ;

д) объекты воздействия угроз безопасности информации и соответствующие им виды воздействия, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. ;

е) виды и категории актуальных нарушителей, которые могут реализовывать угрозы безопасности информации, в том числе непреднамеренные угрозы, и их возможности, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. .

Указанные исходные данные могут быть дополнены иными документами и сведениями с учетом особенностей области деятельности, в которой функционируют системы и сети.

9.1. Подраздел «Описание способов реализации (возникновения) угроз безопасности информации, которые могут быть использованы нарушителями разных видов и категорий»

Основными способами реализации (возникновения) угроз безопасности информации являются:

- 1) использование уязвимостей (уязвимостей кода (программного обеспечения), уязвимостей архитектуры и конфигурации систем и сетей, а также организационных и многофакторных уязвимостей);
- 2) внедрение вредоносного программного обеспечения;
- 3) использование недекларированных возможностей программного обеспечения и (или) программно-аппаратных средств;
- 4) установка программных и (или) программно-аппаратных закладок в программное обеспечение и (или) программно-аппаратные средства;
- 5) формирование и использование скрытых каналов (по времени, по памяти) для передачи конфиденциальных данных;
- 6) перехват (измерение) побочных электромагнитных излучений и наводок (других физических полей) для доступа к конфиденциальной информации, содержащейся в аппаратных средствах аутентификации;
- 7) инвазивные способы доступа к конфиденциальной информации, содержащейся в аппаратных средствах аутентификации;
- 8) нарушение безопасности при поставках программных, программно-аппаратных средств и (или) услуг по установке, настройке, испытаниям, пусконаладочным работам (в том числе администрированию, обслуживанию);
- 9) ошибочные действия в ходе создания и эксплуатации систем и сетей, в том числе при установке, настройке программных и программно-аппаратных средств.

Указанные способы реализации (возникновения) угроз безопасности информации могут быть дополнены иными способами с учетом особенностей архитектуры и условий функционирования систем и сетей.

Способы реализации (возникновения) угроз безопасности информации определяются применительно к объектам воздействия, определенным в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденному ФСТЭК России 5 февраля 2021 г.

Способы являются актуальными, когда возможности нарушителя позволяют их использовать для реализации угроз безопасности и имеются или созданы условия, при которых такая возможность может быть реализована в отношении объектов воздействия. Одна угроза безопасности информации может быть реализована несколькими способами.

9.2. Подраздел «Описание интерфейсов объектов воздействия, доступных для использования нарушителями способов реализации угроз безопасности информации»

Условием, позволяющим нарушителям использовать способы реализации угроз безопасности информации, является наличие у них возможности доступа к следующим типам интерфейсов объектов воздействия:

- внешние сетевые интерфейсы, обеспечивающие взаимодействие с сетью «Интернет», смежными (взаимодействующими) системами или сетями (проводные, беспроводные, веб-интерфейсы, интерфейсы удаленного доступа и др.);
- внутренние сетевые интерфейсы, обеспечивающие взаимодействие (в том числе через промежуточные компоненты) с компонентами систем и сетей, имеющими внешние сетевые интерфейсы (проводные, беспроводные);
- интерфейсы для пользователей (проводные, беспроводные, веб-интерфейсы, интерфейсы удаленного доступа и др.);
- интерфейсы для использования съемных машинных носителей информации и периферийного оборудования;
- интерфейсы для установки, настройки, испытаний, пусконаладочных работ (в том числе администрирования, управления, обслуживания) обеспечения функционирования компонентов систем и сетей;

- возможность доступа к поставляемым или находящимся на обслуживании, ремонте в сторонних организациях компонентам систем и сетей.

Наличие указанных интерфейсов определяется архитектурой, составом и условиями функционирования систем и сетей, группами пользователей, их типами доступа и уровнями полномочий. В ходе анализа должны быть определены как логические, так и физические интерфейсы объектов воздействия, в том числе требующие физического доступа к ним.

Интерфейсы определяются на аппаратном, системном и прикладном уровнях систем и сетей, а также для телекоммуникационного оборудования. Возможность их использования на указанных уровнях определяется возможностями актуальных нарушителей.

На этапе создания систем и сетей определение интерфейсов объектов воздействия, которые могут использоваться для реализации угроз безопасности, проводится на основе предполагаемой архитектуры и условий функционирования систем и сетей, определенных на основе изучения и анализа исходных данных о них.

На этапе эксплуатации систем и сетей для определения интерфейсов объектов воздействия, которые могут использоваться для реализации угроз безопасности, дополнительно к документации на сети и системы используются результаты инвентаризации систем и сетей, проведенной с использованием автоматизированных средств.

По результатам оценки возможных способов реализации угроз безопасности информации должны быть определены:

а) виды и категории нарушителей, которые имеют возможность использования актуальных способов;

б) актуальные способы реализации угроз безопасности информации и типы интерфейсов объектов воздействия, за счет которых они могут быть реализованы.

Примеры определения актуальных способов реализации угроз безопасности информации и соответствующие им виды нарушителей и их возможности приведены в таблице 5.

УЧЕБНЫЙ ЦЕНТР "РЦБ" Г. РЯЗАНЬ

Таблица № 5. Примеры определения актуальных способов реализации угроз безопасности информации

№ п/п	Вид нарушителя	Категория нарушителя	Объект воздействия	Доступные интерфейсы	Способы реализации
1	Специальные службы иностранных государств (Н4)	Внешний	База данных информационной системы, содержащая идентификационную информацию граждан: несанкционированный доступ к компонентам систем или сетей, защищаемой информации, системным, конфигурационным, иным служебным данным; утечка (нарушение конфиденциальности) защищаемой информации, системных, конфигурационных, иных служебных данных	Веб-интерфейс удаленного администрирования базы данных информационной системы	Использование недеklarированных возможностей программного обеспечения телекоммуникационного оборудования
				Пользовательский веб-интерфейс доступа к базе данных информационной системы	Использование уязвимостей конфигурации системы управления базами данных
			Линия связи между сервером основного центра обработки данных и сервером резервного центра обработки данных: перехват (нарушение конфиденциальности) защищаемой информации, системных, конфигурационных, иных служебных данных	Канал передачи данных между сервером основного центра обработки данных и сервером резервного центра обработки данных	Установка программных закладок в телекоммуникационное оборудование
			Коммутационный контроллер для управления аварийными задвижками в нефтепроводе:	Удаленный канал управления коммутационным контроллером	Использование уязвимостей кода коммутационного контроллера

			нарушение функционирования (работоспособности) средств обработки и хранения информации; модификация (подмена) защищаемой информации, системных, конфигурационных, иных служебных данных	Съемные машинные носители информации, содержащие аутентификационную информацию	Извлечение аутентификационной информации из постоянной памяти носителя (инвазивный метод)
2	Отдельные физические лица (хакеры) (Н2)	Внешний	Удаленное автоматизированное рабочее место (АРМ) пользователя: несанкционированный доступ к операционной системе АРМ пользователя; нарушение конфиденциальности информации, содержащейся на АРМ пользователя	Доступ через локальную вычислительную сеть организации	Внедрение вредоносного программного обеспечения
				Съемные машинные носители информации, подключаемые к АРМ пользователя	Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя
			Веб-сайт портала государственных услуг (сервисов): отказ в обслуживании веб-сайта портала государственных услуг	Веб-интерфейс пользователя веб-сайта государственных услуг	Использование уязвимостей кода программного обеспечения веб-сервера
				Сетевые интерфейсы коммутатора сети, где расположен веб-сервер	Внедрение вредоносного кода в веб-приложение Использование уязвимостей конфигурации системы управления доступом к АРМ пользователя

3	Авторизованные пользователи систем и сетей (Н1)	Внутренний	АРМ главного бухгалтера организации: модификация платежных поручений, хранящихся на АРМ главного бухгалтера	Локальная вычислительная сеть организации	Ошибочные действия в ходе настройки АРМ главного бухгалтера
			Сервер базы данных веб-сайта портала государственных услуг (сервисов): отказ в обслуживании отдельных компонентов или систем и сетей в целом	Веб-интерфейс системы администрирования веб-сайта портала государственных услуг	Нарушение цепочки услуг по администрированию портала государственных услуг

10. Раздел «Актуальные угрозы безопасности информации»

В ходе оценки угроз безопасности информации должны быть определены возможные угрозы безопасности информации и оценена их актуальность для систем и сетей – актуальные угрозы безопасности информации.

Исходными данными для оценки актуальности угроз безопасности информации являются:

а) общий перечень угроз безопасности информации, содержащийся в банке данных угроз безопасности информации ФСТЭК России (bdu.fstec.ru), модели угроз безопасности информации, разрабатываемые ФСТЭК России в соответствии с подпунктом 4 пункта 8 Положения о Федеральной службе по техническому и экспортному контролю, утвержденного Указом Президента Российской Федерации от 16 августа 2004 г. № 1085, а также отраслевые (ведомственные, корпоративные) модели угроз безопасности информации;

б) описания векторов компьютерных атак, содержащихся в базах данных и иных информационных источниках, опубликованных в сети «Интернет» (CAPEC, ATT&CK, OWASP, STIX, WASC и др.);

в) негативные последствия от реализации (возникновения) угроз безопасности информации, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. ;

г) объекты воздействия угроз безопасности информации и виды воздействий на них, определенные в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. ;

д) виды и категории актуальных нарушителей, которые могут реализовывать угрозы безопасности информации, в том числе непреднамеренные угрозы, и их возможности, определенные в соответствии

с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г. ;

е) актуальные способы реализации (возникновения) угроз безопасности информации.

10.1. Подраздел «Перечень возможных (вероятных) угроз безопасности информации для соответствующих способов их реализации и уровней возможностей нарушителей»

На основе анализа исходных данных определяются возможные для систем и сетей угрозы безопасности информации, к которым относятся осуществляемые нарушителем воздействия на информационные ресурсы и компоненты систем и сетей (объекты воздействия), в результате которых возможно нарушение безопасности информации и (или) нарушение или прекращение функционирования систем и сетей.

Угроза безопасности информации возможна, если имеются нарушитель или иной источник угрозы, объект, на который осуществляются воздействия, способы реализации угрозы безопасности информации, а реализация угрозы может привести к негативным последствиям.

УБИ_і = [нарушитель (источник угрозы); объекты воздействия; способы реализации угроз; негативные последствия].

10.2. Подраздел «Описание возможных сценариев реализации угроз безопасности информации»

Актуальность возможных угроз безопасности информации определяется наличием сценариев их реализации.

Сценарии реализации угроз безопасности информации должны быть определены для соответствующих способов реализации угроз безопасности информации, определенных в соответствии с методическим документом «Методика оценки угроз безопасности информации», утвержденным ФСТЭК России 5 февраля 2021 г., и применительно к объектам воздействия и видам воздействия на них. Определение сценариев предусматривает установление

последовательности возможных тактик и соответствующих им техник, применение которых возможно актуальным нарушителем с соответствующим уровнем возможностей, а также доступности интерфейсов для использования соответствующих способов реализации угроз безопасности информации.

Перечень основных тактик (тактических задач) и соответствующих им типовых техник, используемых для построения сценариев реализации угроз безопасности информации, приведен в таблице 6.

УЧЕБНЫЙ ЦЕНТР "РЦБ" Г. РЯЗАНЬ

Таблица № 6. Перечень основных тактик (тактических задач) и соответствующих им типовых техник

№	Тактика	Основные техники
T1	Сбор информации о системах и сетях Тактическая задача: нарушитель стремится получить любую техническую информацию, которая может оказаться полезной в ходе реализации угроз безопасности информации	T1.1. Сбор информации из публичных источников: официальный сайт (сайты) организации, СМИ, социальные сети, фотобанки, сайты поставщиков и вендоров, материалы конференций
		T1.2. Сбор информации о подключенных к публичным системам и сетям устройствах и их службах при помощи поисковых систем, включая сбор конфигурационной информации компонентов систем и сетей, программного обеспечения сервисов и приложений. Пример: использование поисковой системы 10.3. для получения информации об определенных моделях IP-камер видеонаблюдения с возможно уязвимыми версиями прошивок
		T1.3. Пассивный сбор (прослушивание) информации о подключенных к сети устройствах с целью идентификации сетевых служб, типов и версий ПО этих служб и в некоторых случаях – идентификационной информации пользователей
		T1.4. Направленное сканирование при помощи специализированного программного обеспечения подключенных к сети устройств с целью идентификации сетевых сервисов, типов и версий программного обеспечения этих сервисов, а также с целью получения конфигурационной информации компонентов систем и сетей, программного обеспечения сервисов и приложений. Пример: сканирование при помощи сканера nmap
		T1.5. Сбор информации о пользователях, устройствах, приложениях, а также сбор конфигурационной информации компонентов систем и сетей, программного обеспечения сервисов и приложений путем поиска и эксплуатации уязвимостей подключенных к сети устройств. Пример: эксплуатация уязвимости типа directory traversal публично доступного веб-сервера
		T1.6. Сбор информации о пользователях, устройствах, приложениях, авторизуемых сервисами вычислительной сети, путем перебора. Пример: сбор информации о почтовых адресах при помощи directoryharvestattack на почтовые сервера
		T1.7. Сбор информации, предоставляемой DNS сервисами, включая DNS Hijacking

	T1.8. Сбор информации о пользователе при посещении им веб-сайта, в том числе с использованием уязвимостей программы браузера и надстраиваемых модулей браузера
	T1.9. Сбор информации о пользователях, устройствах, приложениях путем поиска информации в памяти, файлах, каталогах, базах данных, прошивках устройств, репозиториях исходных кодов ПО, включая поиск паролей в исходном и хэшированном виде, криптографических ключей. Пример: получение хэшей паролей из /etc/passwd или получение паролей по умолчанию путем обратного инжиниринга прошивки устройства
	T1.10. Кража цифровых сертификатов, включая кражу физических токенов, либо неавторизованное выписывание новых сертификатов (возможно после компрометации инфраструктуры доменного регистратора или аккаунта администратора зоны на стороне жертвы)
	T1.11. Сбор информации о пользователях, устройствах, приложениях, внутренней информации о компонентах систем и сетей путем применения социальной инженерии, в том числе фишинга
	T1.12. Сбор личной идентификационной информации (идентификаторы пользователей, устройств, информация об идентификации пользователей сервисами, приложениями, средствами удаленного доступа), в том числе сбор украденных личных данных сотрудников и подрядчиков на случай, если сотрудники/подрядчики используют одни и те же пароли на работе и за ее пределами
	T1.13. Сбор информации через получение доступа к системам физической безопасности и видеонаблюдения
	T1.14. Сбор информации через получение контроля над личными устройствами сотрудников (смартфонами, планшетами, ноутбуками) для скрытой прослушки и видеофиксации
	T1.15. Поиск и покупка баз данных идентификационной информации, скомпрометированных паролей и ключей на специализированных нелегальных площадках
	T1.16. Сбор информации через получение доступа к базам данных результатов проведенных инвентаризаций, реестрам установленного оборудования и ПО, данным проведенных аудитов безопасности, в том числе через получение доступа к таким данным через компрометацию подрядчиков и партнеров

		T1.17. Пассивный сбор и анализ данных телеметрии для получения информации о технологическом процессе, технологических установках, системах и ПО на предприятиях в автоматизированных системах управления производственными и технологическими процессами, в том числе на критически важных объектах
		T1.18. Сбор и анализ данных о прошивках устройств, количестве и подключении этих устройств, используемых промышленных протоколах для получения информации о технологическом процессе, технологических установках, системах и ПО на предприятиях в автоматизированных системах управления производственными и технологическими процессами, в том числе на критически важных объектах
		T1.19. Сбор и анализ специфических для отрасли или типа предприятия характеристик технологического процесса для получения информации о технологических установках, системах и ПО на предприятиях в автоматизированных системах управления производственными и технологическими процессами, в том числе на критически важных объектах
		T1.20. Техники конкурентной разведки и промышленного шпионажа для сбора информации о технологическом процессе, технологических установках, системах и ПО на предприятиях в автоматизированных системах управления производственными и технологическими процессами, в том числе на критически важных объектах
		<i>Примечание 1: Сбор информации может выполняться с использованием одной или более из перечисленных выше техник, пока нарушитель не получит достаточно информации для реализации другой тактики в продолжении атаки</i>
T2	Получение первоначального доступа к компонентам систем и сетей Тактическая задача: нарушитель, находясь вне инфраструктуры сети или системы, стремится получить доступ к любому узлу в инфраструктуре и использовать его как плацдарм для дальнейших действий	T2.1. Использование внешних сервисов организации в сетях публичного доступа (Интернет) Примеры: 1) доступ к веб-серверу, расположенному в сети организации; 2) доступ к интерфейсу электронной почты Outlook Web Access (OWA) почтового сервера организации T2.2. Использование устройств, датчиков, систем, расположенных на периметре или вне периметра физической защиты объекта, для получения первичного доступа к системам и компонентам внутри этого периметра. Примеры 1) доступ к датчикам автономной системы дистанционного контроля давления газа участка газопровода; 2) доступ к умному счетчику, расположенному на частном объекте, как к части инфраструктуры поставщика электроэнергии; 3) доступ к интерфейсу управления камеры видеонаблюдения через сети ближнего действия

	T2.3. Эксплуатация уязвимостей сетевого оборудования и средств защиты вычислительных сетей для получения доступа к компонентам систем и сетей при удаленной атаке. Пример: обход межсетевого экрана путем эксплуатации уязвимостей реализации правил фильтрации
	T2.4. Использование ошибок конфигурации сетевого оборудования и средств защиты, в том числе слабых паролей и паролей по умолчанию, для получения доступа к компонентам систем и сетей при удаленной атаке
	T2.5. Эксплуатация уязвимостей компонентов систем и сетей при удаленной или локальной атаке. Примеры: 1) эксплуатация уязвимостей веб-сервера с целью выполнения произвольного кода в контексте этого сервера; 2) эксплуатация уязвимостей операционной системы устройства человеко-машинного интерфейса автоматизированной системы управления с целью внедрения средств получения вводимых на этом устройстве паролей доступа; 3) эксплуатация уязвимостей браузера вредоносными скриптами при посещении пользователем вредоносного или скомпрометированного веб-сайта
	T2.6. Использование недокументированных возможностей программного обеспечения сервисов, приложений, оборудования, включая использование отладочных интерфейсов, программных, программно-аппаратных закладок
	T2.7. Использование в системе внешних носителей информации, которые могли подключаться к другим системам и быть заражены вредоносным программным обеспечением. В том числе дарение, подмена или подлог носителей информации и внешних устройств, содержащих вредоносное программное обеспечение или предназначенных для реализации вредоносных функций. Примеры: 1) передача флеш-носителя в комплекте материалов выездного мероприятия; 2) подмена USB-адаптера беспроводной клавиатуры схожим внешне, но реализующим функции сбора и передачи данных устройством
	T2.8. Использование методов социальной инженерии, в том числе фишинга, для получения прав доступа к компонентам системы
	T2.9. Несанкционированное подключение внешних устройств. Пример: несанкционированное подключение точки доступа Wi-Fi
	T2.10. Несанкционированный доступ путем подбора учетных данных сотрудника или легитимного пользователя (методами прямого перебора, словарных атак, паролей

		производителей по умолчанию, использования одинаковых паролей для разных учетных записей, применения «радужных» таблиц или другими)
		T2.11. Несанкционированный доступ путем компрометации учетных данных сотрудника организации, в том числе через компрометацию многократно используемого в различных системах пароля (для личных или служебных нужд)
		T2.12. Использование доступа к системам и сетям, предоставленного сторонним организациям, в том числе через взлом инфраструктуры этих организаций, компрометацию личного оборудования сотрудников сторонних организаций, используемого для доступа. Пример: использование доступа третьей доверенной стороны (поставщика ИТ-услуг, поставщика услуг безопасности)
		T2.13. Реализация атаки типа «человек посередине» для осуществления доступа, например, NTLM/SMB Relaying атаки
		T2.14. Доступ путем эксплуатации недостатков систем биометрической аутентификации. Пример: демонстрация фотографии для аутентификации через функцию распознавания лиц
		<i>Примечание 2: Получение доступа может выполняться в несколько шагов с использованием одной или более из перечисленных выше техник, пока нарушитель не достигнет целевой системы или не будет вынужден прибегнуть к другой тактике для продолжения атаки</i>
ТЗ	Внедрение и исполнение вредоносного программного обеспечения в системах и сетях Тактическая задача: получив доступ к узлу сети или системы, нарушитель стремится внедрить в его программную среду инструментальные средства, необходимые ему для дальнейших действий	T3.1. Автоматический запуск скриптов и исполняемых файлов в системе с использованием пользовательских или системных учетных данных, в том числе с использованием методов социальной инженерии
		T3.2. Активация и выполнение вредоносного кода, внедренного в виде закладок в легитимное программное и программное-аппаратное обеспечение систем и сетей
		T3.3. Автоматическая загрузка вредоносного кода с удаленного сайта или ресурса с последующим запуском на выполнение
		T3.4. Копирование и запуск скриптов и исполняемых файлов через средства удаленного управления операционной системой и сервисами
		T3.5. Эксплуатация уязвимостей типа удаленное исполнение программного кода (RCE, Remotecodeexecution)
		T3.6. Автоматическое создание вредоносных скриптов при помощи доступного инструментария от имени пользователя в системе с использованием его учетных данных

	T3.7. Подмена файлов легитимных программ и библиотек непосредственно в системе. <i>Примечание 3: В том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа ПО</i>
	T3.8. Подмена легитимных программ и библиотек, а также легитимных обновлений программного обеспечения, поставляемых производителем удаленно через сети связи, в репозиториях поставщика или при передаче через сети связи. <i>Примечание 4: В том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа программного обеспечения</i>
	T3.9. Подмена ссылок на легитимные программы и библиотеки, а также на легитимные обновления программного обеспечения, поставляемые производителем удаленно через сети связи, подмена информации о таких обновлениях, включая атаки на инфраструктурные сервисы поставщика (такие как DNS hijacking), атаки на третьесторонние ресурсы, атаки на электронную почту и другие средства обмена сообщениями. <i>Примечание 5: В том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа программного обеспечения</i>
	T3.10. Подмена дистрибутивов (установочных комплектов) программ на носителях информации или общих сетевых ресурсах <i>Примечание 6: В том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа программного обеспечения</i>
	T3.11. Компрометация сертификата, используемого для цифровой подписи образа ПО, включая кражу этого сертификата у производителя ПО или покупку краденного сертификата на нелегальных площадках в сетях связи (т.н. «дарквеб») и подделку сертификата с помощью эксплуатации уязвимостей ПО, реализующего функции генерирования криптографических ключей, хранения и управления цифровыми сертификатами
	T3.12. Компрометация средств создания программного кода приложений в инфраструктуре разработчика этих приложений (компиляторов, линковщиков, средств управления разработкой) для последующего автоматизированного внесения изменений в этот код, устанавливаемый авторизованным пользователем на целевые для нарушителя системы
	T3.13. Компрометация средств сборки, конфигурирования и разворачивания программного кода, а также средств создания узкоспециализированного кода (к примеру, кода промышленных контроллеров) в инфраструктуре целевой системы для автоматизированного

		внесения изменений в этот код, устанавливаемый авторизованным пользователем на целевые для нарушителя системы
		T3.14. Планирование запуска вредоносных программ при старте операционной системы путем эксплуатации стандартных механизмов, в том числе путем правки ключей реестра, отвечающих за автоматический запуск программ, запуска вредоносных программ как сервисов и т.п.
		T3.15. Планирование запуска вредоносных программ через планировщики задач в операционной системе, а также с использованием механизмов планирования выполнения в удаленной системе через удаленный вызов процедур. Выполнение в контексте планировщика в ряде случаев позволяет авторизовать вредоносное программное обеспечение и повысить доступные ему привилегии
		T3.16. Запуск вредоносных программ при помощи легитимных, подписанных цифровой подписью утилит установки приложений и средств запуска скриптов (т.н. техника проксирования запуска), а также через средства запуска кода элементов управления ActiveX, компонентов фильтров (кодеков) и компонентов библиотек DLL. Примеры: 1) запуск MSI-файлов в операционной системе Windows при помощи утилиты msixexec; 2) использование утилит Regsvr32.exe (Microsoft Windows RegisterServer) и odbccconf.exe для проксирования исполнения кода библиотек dll в операционной системе Windows посредством внесения изменений в реестр операционных систем
		<i>Примечание 7: Внедрение и исполнение вредоносного программного обеспечения в системах и сетях может выполняться в несколько шагов с использованием одной или более из перечисленных выше техник, пока нарушитель не достигнет целевой системы или не будет вынужден прибегнуть к другой тактике для продолжения атаки</i>
T4	Закрепление (сохранение доступа) в системе или сети Тактическая задача: получив доступ к узлу сети с помощью некоторой последовательности действий, нарушитель стремится упростить себе повторное получение доступа к этому узлу, если он ему впоследствии	T4.1. Несанкционированное создание учетных записей или кража существующих учетных данных
		T4.2. Использование штатных средств удаленного доступа и управления операционной системы
		T4.3. Скрытая установка и запуск средств удаленного доступа и управления операционной системы. Внесение изменений в конфигурацию и состав программных и программно-аппаратных средств атакуемой системы или сети, вследствие чего становится возможен многократный запуск вредоносного кода

	понадобится (например, устанавливает средства удаленного управления узлом, изменяет настройки средств защиты и другие действия)	T4.4. Маскирование подключенных устройств под легитимные (например, нанесение корпоративного логотипа, инвентарного номера, телефона службы поддержки) T4.5. Внесение соответствующих записей в реестр, автозагрузку, планировщики заданий, обеспечивающих запуск вредоносного программного обеспечения при перезагрузке системы или сети T4.6. Компрометация прошивок устройств с использованием уязвимостей или программно-аппаратных закладок, к примеру, внедрение новых функций в BIOS (UEFI), компрометация прошивок жестких дисков T4.7. Резервное копирование вредоносного кода в областях, редко подвергаемых проверке, в том числе заражение резервных копий данных, сохранение образов в неразмеченных областях жестких дисков и сменных носителей <i>Примечание 8: Закрепление (сохранение доступа в системе) может производиться с использованием одной или более из перечисленных выше техник</i>
T5	Управление вредоносным программным обеспечением и (или) компонентами, к которым ранее был получен доступ Тактическая задача: внедрив вредоносное программное обеспечение или обеспечив постоянное присутствие на узле сети, нарушитель стремится автоматизировать управление внедренными инструментальными средствами, организовав взаимодействия скомпрометированным узлом и сервером управления, который может быть размещен в сети Интернет или в инфраструктуре организации	T5.1. Удаленное управление через стандартные протоколы (например, RDP, SSH), а также использование инфраструктуры провайдеров средств удаленного администрирования. Пример: использование средств удаленного управления RMS/teamviewer для создания канала связи и управления скомпрометированной системой со стороны злоумышленников T5.2. Использование штатных средств удаленного доступа и управления операционной системы T5.3. Коммуникация с внешними серверами управления через хорошо известные порты на этих серверах, разрешенные на межсетевом экране (SMTP/25, HTTP/80, HTTPS/443 и др.) T5.4. Коммуникация с внешними серверами управления через нестандартные порты на этих серверах, что в некоторых случаях позволяет эксплуатировать уязвимости средств сетевой фильтрации для обхода этих средств T5.5. Управление через съемные носители, в частности, передача команд управления между скомпрометированными изолированной системой и подключенной к Интернет системой через носители информации, используемые на обеих системах T5.6. Проксирование трафика управления для маскировки подозрительной сетевой активности, обхода правил на межсетевом экране и сокрытия адресов инфраструктуры нарушителей, дублирование каналов связи, обфускация и разделение трафика управления во избежание обнаружения.

		Примеры: 1) использование скомпрометированных систем в той же сети, для которых правилами МЭ разрешен доступ в Интернет, в качестве прокси серверов; 2) использование инфраструктуры сети TOR для проксирования запросов к серверам управления; 3) использование одного коммуникационного протокола для запроса, и другого – для ответа на запрос
		T5.7. Туннелирование трафика управления через VPN
		T5.8. Туннелирование трафика управления в поля заполнения и данных служебных протоколов, к примеру, туннелирование трафика управления в поля данных и заполнения протоколов DNS, ICMP или другие
		T5.9. Управление через подключенные устройства, реализующие дополнительный канал связи с внешними системами или между скомпрометированными системами в сети
		T5.10. Использование средств обфускации, шифрования, стеганографии для сокрытия трафика управления
		T5.11. Передача команд управления через нестандартно интерпретируемые типовые операции, к примеру, путем выполнения копирования файла по разрешенному протоколу (FTP или подобному), путем управления разделяемыми сетевыми ресурсами по протоколу SMB и т.п.
		T5.12. Передача команд управления через публикацию на внешнем легитимном сервисе, таком как веб-сайт, облачный ресурс, ресурс в социальной сети и т.п.
		T5.13. Динамическое изменение адресов серверов управления, идентификаторов внешних сервисов, на которых публикуются команды управления, и т.п. по известному алгоритму во избежание обнаружения
		<i>Примечание 9: Управление вредоносным программным обеспечением и (или) компонентами, к которым ранее был получен доступ, может производиться нарушителем с использованием одной или более из перечисленных выше техник для управления труднодоступными компонентами или для реализации резервных каналов управления</i>
T6	Повышение привилегий по доступу к компонентам систем и сетей	T6.1. Получение данных для аутентификации и авторизации от имени привилегированной учетной записи путем поиска этих данных в папках и файлах, поиска в памяти или перехвата в сетевом трафике. Данные для авторизации включают пароли, хэш-суммы паролей, токены, идентификаторы сессии, криптографические ключи, но не ограничиваются ими

	Тактическая задача: получив первоначальный доступ к узлу с привилегиями, недостаточными для совершения нужных ему действий, нарушитель стремится повысить полученные привилегии и получить контроль над узлом	T6.2. Подбор пароля или другой информации для аутентификации от имени привилегированной учетной записи
		T6.3 Эксплуатация уязвимостей ПО к повышению привилегий. Пример: эксплуатация уязвимости драйвера службы печати, позволяющей выполнить код с привилегиями системной учетной записи, через доступ к этому драйверу из приложения, запущенного от имени непривилегированного пользователя
		T6.4. Эксплуатация уязвимостей механизма имперсонации (запуска операций в системе от имени другой учетной записи). Пример: эксплуатация уязвимости штатного механизма имперсонации, реализуемого операционной системой
		T6.5. Манипуляции с идентификатором сессии, токеном доступа или иным параметром, определяющим права и полномочия пользователя в системе таким образом, что новый или измененный идентификатор/токен/параметр дает возможность выполнения ранее недоступных пользователю операций. Пример: кража и подделка cookie сессии для получения авторизованного доступа к веб-интерфейсу управления сетевого устройства
		T6.6. Обход политики ограничения пользовательских учетных записей в выполнении групп операций, требующих привилегированного режима. Пример: обход UserAccountControl в операционной системе Windows
		T6.7. Использование уязвимостей конфигурации системы, служб и приложений, в том числе предварительно сконфигурированных профилей привилегированных пользователей, автоматически запускаемых от имени привилегированных пользователей скриптов, приложений и экземпляров окружения, позволяющих вредоносному ПО выполняться с повышенными привилегиями. Примеры: 1) использование профилей PowerShell для закрепления вредоносного ПО в системе и выполнения этого ПО с повышенными привилегиями; 2) конфигурация команды перехода в привилегированный режим sudo, при которой успешный результат выполнения этой команды на некоторое время кэшируется, что при определенных обстоятельствах может быть использовано вредоносным кодом для выполнения привилегированных операций в течение этого времени; 3) параметры исполнения файлов (ImageFileExecutionOptions, IFEO), позволяющие переключать исполнение файлов в режим отладки, выполняя вредоносные

		приложения под видом отладчиков и средств мониторинга, что позволяет им отключать системные приложения и средства защиты
		Т6.8. Эксплуатация уязвимостей, связанных с отдельным, и вероятно менее строгим контролем доступа к некоторым ресурсам (например, к файловой системе) для непривилегированных учетных записей. Пример: подмена на диске бинарных файлов или скриптов, предназначенных для исполнения в привилегированном контексте, приложением, исполняющимся в непривилегированном контексте
		Т6.9. Эксплуатация уязвимостей средств ограничения среды исполнения (виртуальные машины, песочницы и т.п.) для исполнения кода вне этой среды. Пример: эксплуатация уязвимости обработки буфера данных в рамках песочницы, реализуемой браузером для ограничения работы мобильного кода (Javascript), с последующим выполнением кода в контексте процесса браузера
		<i>Примечание 10: Повышение привилегий по доступу к компонентам систем и сетей может производиться с использованием одной или более из перечисленных выше техник, пока нарушитель не получит достаточно привилегий для реализации другой тактики в продолжении атаки</i>
Т7	Соккрытие действий и применяемых при этом средств от обнаружения Тактическая задача: нарушитель стремится затруднить применение мер защиты информации, которые способны помешать его действиям или обнаружить их	Т7.1. Использование нарушителем или вредоносной платформой штатных инструментов администрирования, утилит и сервисов операционной системы, сторонних утилит, в том числе двойного назначения. Пример: использование популярной утилиты PsExec для ОС Windows как администраторами, так и нарушителями
		Т7.2. Очистка/затирание истории команд и журналов регистрации, перенаправление записей в журналы регистрации, переполнение истории команд и журналов регистрации, затруднение доступа к журналам регистрации для авторизованных пользователей
		Т7.3. Удаление файлов, переписывание файлов произвольными данными, форматирование съемных носителей
		Т7.4. Отключение средств защиты от угроз информационной безопасности, в том числе средств антивирусной защиты, механизмов аудита, консолей оператора мониторинга и средств защиты других типов

	T7.5. Отключение систем и средств мониторинга и защиты от угроз промышленной, физической, пожарной, экологической, радиационной безопасности, иных видов безопасности автоматизированной системы управления технологическими процессами и управляемого (контролируемого) объекта и (или) процесса
	T7.6. Подделка данных вывода средств защиты от угроз информационной безопасности
	T7.7. Подделка данных телеметрии, данных вывода автоматизированных систем управления, данных систем и средств мониторинга и защиты от угроз промышленной, физической, пожарной, экологической, радиационной безопасности, иных видов безопасности автоматизированной системы управления технологическими процессами и управляемого (контролируемого) объекта и (или) процесса, данных видеонаблюдения и других визуально или автоматически интерпретируемых данных
	T7.8. Выполнение атаки отказа в обслуживании на основные и резервные каналы связи, которые могут использоваться для доставки сообщений о неработоспособности систем или их компонентов или о других признаках атаки
	T7.9. Подписание кода, включая использование скомпрометированных сертификатов авторитетных производителей ПО для подписания вредоносных программных модулей. <i>Примечание 11: Сочетается с техникой компрометации сертификата, используемого для цифровой подписи образа ПО</i>
	T7.10. Внедрение вредоносного кода в доверенные процессы операционной системы и другие объекты, которые не подвергаются анализу на наличие такого кода, для предотвращения обнаружения
	T7.11. Модификация модулей и конфигурации вредоносного программного обеспечения для затруднения его обнаружения в системе. Пример: внесение изменений в модули и конфигурацию вредоносного ПО для удаления индикаторов компрометации этим ВПО после обнаружения его в других системах
	T7.12. Манипуляции именами и параметрами запуска процессов и приложений для обеспечения скрытности. Примеры: 1) сокрытие окна приложения через параметры запуска процесса в ОС Windows; 2) выбор для вредоносного приложения имени файла (процесса), похожего на имя известного и/или системного приложения или совпадающего с ним

	T7.13. Создание скрытых файлов, скрытых учетных записей
	T7.14. Установление ложных доверенных отношений, в том числе установка корневых сертификатов для успешной валидации вредоносных программных модулей и авторизации внешних сервисов
	T7.15. Внедрение вредоносного кода выборочным/целевым образом на наиболее важные системы или системы, удовлетворяющие определенным критериям, во избежание преждевременной компрометации информации об используемых при атаке уязвимостях и обнаружения факта атаки
	T7.16. Искусственное временное ограничение распространения или активации вредоносного кода внутри сети, во избежание преждевременного обнаружения факта атаки. Пример: распространение вредоносного ПО одновременно по всем интересующим злоумышленникам системам и одновременный запуск его на выполнение по команде, вплоть до выполнения которой компрометацию системы обнаружить сложно
	T7.17. Обфускация, шифрование, упаковка с защитой паролем или сокрытие стеганографическими методами программного кода вредоносного ПО, данных и команд управляющего трафика, в том числе при хранении этого кода и данных в атакуемой системе, при хранении на сетевом ресурсе или при передаче по сети
	T7.18. Использование средств виртуализации для сокрытия вредоносного кода или вредоносной активности от средств обнаружения в операционной системе
	T7.19. Туннелирование трафика управления через VPN
	T7.20. Туннелирование трафика управления в поля заполнения и данных служебных протоколов, к примеру, туннелирование трафика управления в поля данных и заполнения протоколов DNS, ICMP или другие
	T7.21. Изменение конфигурации сети, включая изменение конфигурации сетевых устройств, организацию прокси-соединений, изменение таблиц маршрутизации, сброс и модификацию паролей доступа к интерфейсам управления сетевыми устройствами
	T7.22. Подмена и компрометация прошивок, в том числе прошивок BIOS, жестких дисков

	T7.23. Подмена файлов легитимных программ и библиотек непосредственно в системе. <i>Примечание 12: В том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа ПО</i>
	T7.24. Подмена легитимных программ и библиотек, а также легитимных обновлений программного обеспечения, поставляемых производителем удаленно через сети связи, в репозиториях поставщика или при передаче через сети связи. <i>Примечание 13: В том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа ПО</i>
	T7.25. Подмена ссылок на легитимные программы и библиотеки, а также на легитимные обновления программного обеспечения, поставляемые производителем удаленно через сети связи, информации о таких обновлениях, включая атаки на инфраструктурные сервисы поставщика (такие как DNS hijacking), атаки на третьесторонние ресурсы, атаки на электронную почту и другие средства обмена сообщениями. <i>Примечание 14: в том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа ПО</i>
	T7.26. Подмена дистрибутивов (установочных комплектов) программ на носителях информации или общих сетевых ресурсах. <i>Примечание 15: в том числе может сочетаться с техникой компрометации сертификата, используемого для цифровой подписи образа ПО</i>
	T7.27. Компрометация сертификата, используемого для цифровой подписи образа ПО, включая кражу этого сертификата у производителя ПО или покупку краденного сертификата на нелегальных площадках в сетях связи (т.н. «дарквеб») и подделку сертификата с помощью эксплуатации уязвимостей ПО, реализующего функции генерирования криптографических ключей, хранения и управления цифровыми сертификатами
	T7.28. Компрометация средств создания программного кода приложений в инфраструктуре разработчика этих приложений (компиляторов, линковщиков, средств управления разработкой) для последующего автоматизированного внесения изменений в этот код, устанавливаемый авторизованным пользователем на целевые для нарушителя системы
	T7.29. Компрометация средств сборки, конфигурирования и разворачивания программного кода, а также средств создания узкоспециализированного кода (к примеру, кода промышленных контроллеров), в инфраструктуре целевой системы, для автоматизированного

		внесения изменений в этот код, устанавливаемый авторизованным пользователем на целевые для нарушителя системы <i>Примечание 16: Соккрытие действий и применяемых при этом средств от обнаружения может производиться с использованием одной или более из перечисленных выше техник для сокращения разных свидетельств компрометации системы или для более эффективного сокращения</i>
T8	Получение доступа (распространение доступа) к другим компонентам систем и сетей или смежным системам и сетям Тактическая задача: получив доступ к некоторым узлам инфраструктуры, нарушитель стремится получить доступ к другим узлам. Подобное распространение доступа может быть нецеленаправленным: так, еще не зная, к каким именно компонентам инфраструктуры требуется получить доступ для того, чтобы вызвать нужные ему негативные последствия, нарушитель может стремиться получить контроль над как можно большей частью инфраструктуры систем и сетей	T8.1. Эксплуатация уязвимостей для повышения привилегий в системе или сети для удаленного выполнения программного кода для распространения доступа T8.2. Использование средств и интерфейсов удаленного управления для получения доступа к смежным системам и сетям T8.3. Использование механизмов дистанционной установки программного обеспечения и конфигурирования. Пример: распространение вредоносного кода групповыми политиками ActiveDirectory, обычно используемыми для автоматического управления легитимным программным обеспечением T8.4. Удаленное копирование файлов, включая модули вредоносного программного обеспечения и легитимные программные средства, которые позволяют злоумышленнику получать доступ к смежным системам и сетям T8.5. Изменение конфигурации сети, включая изменение конфигурации сетевых устройств, организацию прокси-соединений, изменение таблиц маршрутизации, сброс и модификацию паролей доступа к интерфейсам управления сетевыми устройствами T8.6. Копирование вредоносного кода на съемные носители T8.7. Размещение вредоносных программных модулей на разделяемых сетевых ресурсах в сети T8.8. Использование доверенных отношений скомпрометированной системы и пользователей этой системы с другими системами и пользователями для распространения вредоносного программного обеспечения или для доступа к системам и информации в других системах и сетях. Пример: отсылка сообщений корпоративной электронной почты от имени коллег и прочих доверенных лиц

		<i>Примечание 17: Получение доступа (распространение доступа) к другим компонентам систем и сетей или смежным системам и сетям может выполняться в несколько шагов с использованием одной или более из перечисленных выше техник, пока нарушитель не достигнет целевой системы или не будет вынужден прибегнуть к другой тактике для продолжения атаки</i>
T9	Сбор и вывод из системы или сети информации, необходимой для дальнейших действий при реализации угроз безопасности информации или реализации новых угроз Тактическая задача: в ходе реализации угроз безопасности информации, нарушителю может потребоваться получить и вывести за пределы инфраструктуры большие объемы информации, избежав при этом обнаружения или противодействия	T9.1. Доступ к системе для сбора информации и вывод информации через стандартные протоколы управления (например, RDP, SSH), а также использование инфраструктуры провайдеров средств удаленного администрирования. Пример: использование средств удаленного управления RMS / teamviewer для создания канала связи и управления скомпрометированной системой со стороны злоумышленников T9.2. Доступ к системе для сбора информации и вывод информации через использование штатных средств удаленного доступа и управления операционной системы T9.3. Вывод информации на хорошо известные порты на внешних серверах, разрешенные на межсетевом экране (SMTP/25, HTTP/80, HTTPS/443 и др.) T9.4. Вывод информации на нестандартные порты на внешних серверах, что в некоторых случаях позволяет эксплуатировать уязвимости средств сетевой фильтрации для обхода этих средств T9.5. Отправка данных по известным протоколам управления и передачи данных T9.6. Отправка данных по собственным протоколам T9.7. Проксирование трафика передачи данных для маскировки подозрительной сетевой активности, обхода правил на межсетевом экране и сокрытия адресов инфраструктуры нарушителей, дублирование каналов связи, обфускация и разделение трафика передачи данных во избежание обнаружения. Примеры: 1) использование скомпрометированных систем в той же сети, для которых правилами МЭ разрешен доступ в Интернет в качестве прокси-серверов; 2) использование инфраструктуры сети TOR для проксирования запросов к серверам управления; 3) использование одного коммуникационного протокола для запроса, и другого – для ответа на запрос T9.8. Туннелирование трафика передачи данных через VPN

		T9.9. Туннелирование трафика управления в поля заполнения и данных служебных протоколов, к примеру, туннелирование трафика управления в поля данных и заполнения протоколов DNS, ICMP или другие
		T9.10. Вывод информации через съемные носители, в частности, передача данных между скомпрометированными изолированной системой и подключенной к Интернет системой через носители информации, используемые на обеих системах
		T9.11. Отправка данных через альтернативную среду передачи данных. Пример: вывод конфиденциальной информации через субтитры видеоряда, демонстрируемого на веб-сайте
		T9.12. Шифрование выводимой информации, использование стеганографии для сокрытия факта вывода информации
		T9.13. Вывод информации через предоставление доступа к файловым хранилищам и базам данных в инфраструктуре скомпрометированной системы или сети, в том числе путем создания новых учетных записей или передачи данных для аутентификации и авторизации имеющихся учетных записей
		T9.14. Вывод информации путем размещения сообщений или файлов на публичных ресурсах, доступных для анонимного нарушителя (форумы, файлообменные сервисы, фотобанки, облачные сервисы, социальные сети)
		<i>Примечание 18: Сбор и вывод из системы или сети информации, необходимой для дальнейших действий при реализации угроз безопасности информации или реализации новых угроз может выполняться с использованием одной или более из перечисленных выше техник для реализации резервных каналов вывода информации</i>
T10	Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящие к негативным последствиям	T10.1. Несанкционированный доступ к информации в памяти системы, файловой системе, базах данных, репозиториях, в программных модулях и прошивках
		T10.2. Несанкционированное воздействие на системное программное обеспечение, его конфигурацию и параметры доступа
		T10.3. Несанкционированное воздействие на программные модули прикладного программного обеспечения
	Тактическая задача: достижение нарушителем конечной цели,	T10.4. Несанкционированное воздействие на программный код, конфигурацию и параметры доступа прикладного программного обеспечения

приводящее к реализации моделируемой угрозы и причинению недопустимых негативных последствий	T10.5. Несанкционированное воздействие на программный код, конфигурацию и параметры доступа системного программного обеспечения
	T10.6. Несанкционированное воздействие на программный код, конфигурацию и параметры доступа прошивки устройства
	T10.7. Подмена информации (например, платежных реквизитов) в памяти или информации, хранимой в виде файлов, информации в базах данных и репозиториях, информации на неразмеченных областях дисков и сменных носителей
	T10.8. Уничтожение информации, включая информацию, хранимую в виде файлов, информацию в базах данных и репозиториях, информацию на неразмеченных областях дисков и сменных носителей
	T10.9. Добавление информации (например, дефейсинг корпоративного портала, публикация ложной новости)
	T10.10. Организация отказа в обслуживании одной или нескольких систем, компонентов системы или сети
	T10.11. Нецелевое использование ресурсов системы. Примеры: 1) организация майнинговой платформы; 2) организация платформы для осуществления атак отказа в обслуживании на смежные системы и сети.
	T10.12. Несанкционированное воздействие на автоматизированные системы управления с целью вызова отказа или нарушения функций управления, в том числе на АСУ критически важных объектов, потенциально опасных объектов, объектов, представляющих повышенную опасность для жизни и здоровья людей и для окружающей природной среды, в том числе опасных производственных объектов. Примеры: 1) воздействие на автоматизированные системы управления объектов транспорта; 2) удаленное воздействие на цифровые системы и первичное оборудование объектов электроэнергетики; 3) воздействие на системы управления технологическим процессом нефтехимического объекта
	T10.13. Несанкционированное воздействие на автоматизированные системы управления с целью вызова отказа или поломки оборудования, в том числе АСУ критически важных объектов, потенциально опасных объектов, объектов, представляющих повышенную опасность для жизни и здоровья людей и для окружающей природной среды, в том числе опасных производственных объектов

	T10.14. Отключение систем и средств мониторинга и защиты от угроз промышленной, физической, пожарной, экологической, радиационной безопасности, иных видов безопасности, в том числе критически важных объектов, потенциально опасных объектов, объектов, представляющих повышенную опасность для жизни и здоровья людей и для окружающей природной среды, в том числе опасных производственных объектов T10.15. Воздействие на информационные ресурсы через системы распознавания визуальных, звуковых образов, системы геопозиционирования и ориентации, датчики вибрации, прочие датчики и системы преобразования сигналов физического мира в цифровое представление с целью полного или частичного вывода системы из строя или несанкционированного управления системой. Примеры: 1) нанесение нелегитимной разметки дорожного полотна с целью вызова сбоя системы автоматического управления автомобилем; 2) использование специальных символов в идентификационном знаке физического объекта, распознаваемом камерами видеонаблюдения <i>Примечание 19: Несанкционированный доступ и (или) воздействие на информационные ресурсы или компоненты систем и сетей, приводящее к негативным последствиям при реализации угроз безопасности информации или реализации новых угроз, может выполняться с использованием одной или более из перечисленных выше техник для повышения эффективности воздействия с точки зрения нарушителя или для реализации нескольких типов воздействия на атакуемую систему</i>
--	--

10.4. Подраздел «Выводы об актуальности угроз безопасности информации»

На этапе создания систем и сетей должен быть определен хотя бы один сценарий каждого способа реализации возможной угрозы безопасности информации. Сценарий определяется для каждого актуального нарушителя и их уровней возможностей.

При наличии хотя бы одного сценария угрозы безопасности информации такая угроза признается актуальной для системы и сети и включается в модель угроз безопасности систем и сетей для обоснования выбора организационных и технических мер по защите информации (обеспечению безопасности), а также выбора средств защиты информации (рисунок 5).

Угроза несанкционированного доступа к базе данных, содержащей защищаемую информацию

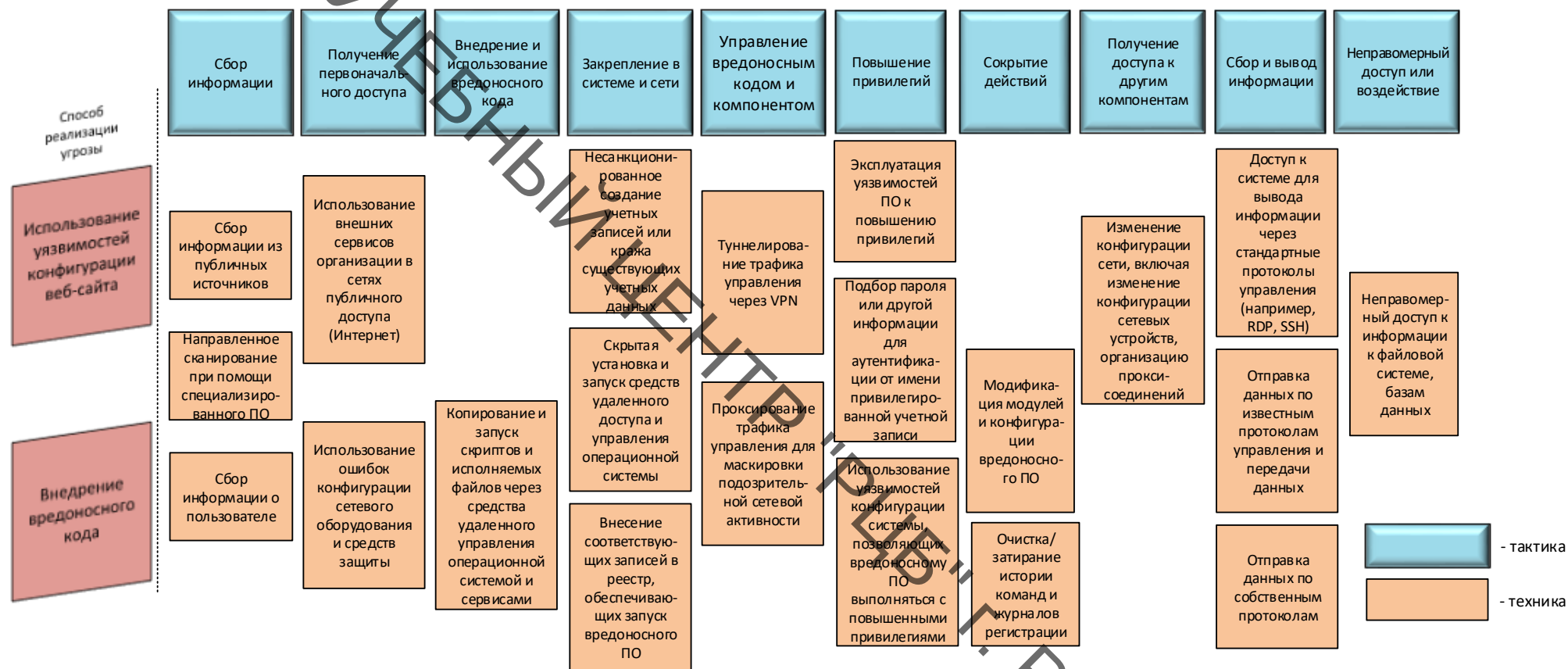


Рисунок 5. Пример сценария реализации угрозы безопасности информации

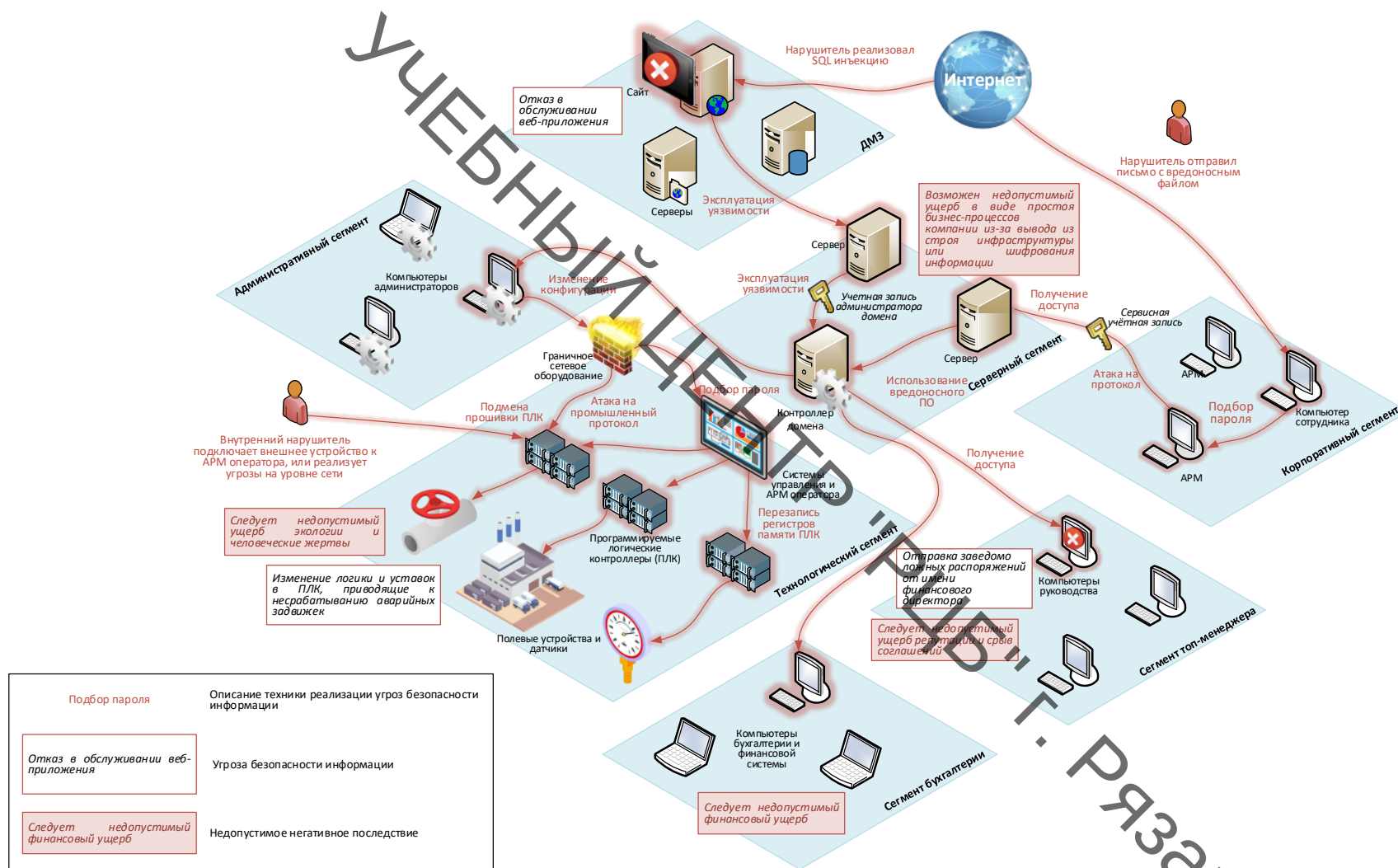


Рисунок 6. Пример сценариев реализации угроз безопасности информации

На этапе эксплуатации систем и сетей для каждой возможной угрозы безопасности информации определяется множество возможных сценариев ее реализации в интересах оценки эффективности принятых технических мер по защите информации (обеспечению безопасности), в том числе средств защиты информации. При этом множество сценариев определяется для каждого актуального нарушителя и уровней его возможностей в соответствии с полученными результатами инвентаризации систем и сетей, анализа уязвимостей и (или) тестирования на проникновение, проведенных с использованием автоматизированных средств (рисунок 6).

На этапе эксплуатации определение сценариев реализации угрозы включает:

- а) анализ исходных данных на систему или сеть, предусматривающий в том числе анализ документации, модели угроз безопасности информации, применяемых средств защиты информации, и определение планируемых к применению автоматизированных средств;
- б) проведение инвентаризации информационных систем и сетей и определение объектов воздействия и их интерфейсов;
- в) определение внешних интерфейсов, которые могут быть задействованы при реализации угроз безопасности информации;
- г) определение внутренних интерфейсов, которые могут быть задействованы при реализации угроз безопасности информации;
- д) выявление уязвимостей объектов воздействия, а также компонентов систем и сетей, имеющих внешние интерфейсы, с которыми посредством внутренних интерфейсов взаимодействуют объекты воздействия;
- е) проведение тестирования на проникновение, подтверждающего возможность использования выявленных уязвимостей или выявления новых сценариев реализации угрозы безопасности информации;
- ж) поиск последовательности тактик и техник, применение которых может привести к реализации угрозы безопасности информации, исходя

из уровня возможностей актуальных нарушителей, а также результатов инвентаризации, анализа уязвимостей и тестирования на проникновение;

з) составление сценариев реализации угрозы безопасности информации применительно к объектам и видам воздействия, а также способам реализации угроз безопасности информации.

11. Раздел «Определение актуальности использования СКЗИ и угроз, нейтрализуемых только с помощью СКЗИ»

Разработка данного раздела необходима в случае включения в подсистему защиты информационной системы криптографических средств защиты информации.

В случае, если в информационной системе обрабатываются персональные данные при разработке данного раздела необходимо руководствоваться положениями документа «Методические рекомендации по разработке нормативных правовых актов, определяющих угрозы безопасности персональных данных, актуальные при обработке персональных данных в информационных системах персональных данных, эксплуатируемых при осуществлении соответствующих видов деятельности», утвержденного приказом от 31 марта 2015 года № 149/7/2/6-432/8 Центра ФСБ России.

В случае, если информационная система является государственной, муниципальной или информационной системой, в которой обрабатывается информация ограниченного доступа (за исключением информации, содержащей персональные данные или сведения, составляющие государственную тайну) необходимо в начале данного раздела привести обоснование использования криптографических средств защиты информации в информационной системе, а уже в последствии можно воспользоваться положениями выше названного методического документа.

11.1. Подраздел «Определение актуальности использования СКЗИ для обеспечения безопасности информации»

Использование средств криптографической защиты информации (далее – СКЗИ) для обеспечения безопасности информации необходимо в следующих случаях:

- если информация подлежат криптографической защите в соответствии с законодательством Российской Федерации;
- если в информационной системе существуют угрозы, которые могут быть нейтрализованы только с помощью СКЗИ.

Кроме того, решение о необходимости криптографической защиты информации может быть принято конкретным оператором на основании технико-экономического сравнения альтернативных вариантов обеспечения требуемых характеристик безопасности информации, содержащей, в том числе, персональные данные.

В случае обработки в информационной системе персональных данных к возможным сценариям, когда угрозы могут быть нейтрализованы только с помощью СКЗИ, относятся:

- передача персональных данных по каналам связи, не защищенным от перехвата нарушителем передаваемой по ним информации или от несанкционированных воздействий на эту информацию (например, при передаче персональных данных по информационно-телекоммуникационным сетям общего пользования);
- хранение персональных данных на носителях информации, несанкционированный доступ к которым со стороны нарушителя не может быть исключен с помощью некриптографических методов и способов.

При этом согласно Методических рекомендаций ФСБ России № 149/7/2/6-432 от 31.03.2015 необходимо учитывать следующее:

– криптографическая защита персональных данных может быть обеспечена при условии отсутствия возможности несанкционированного доступа нарушителя к ключевой информации СКЗИ;

– СКЗИ штатно функционируют совместно с техническими и программными средствами, которые способны повлиять на выполнение предъявляемых к СКЗИ требований и которые образуют среду функционирования СКЗИ;

– СКЗИ не предназначены для защиты информации от действий, выполняемых в рамках предоставленных субъекту действий полномочий (например, СКЗИ не предназначены для защиты персональных данных от раскрытия лицами, которым предоставлено право на доступ к этой информации);

– СКЗИ обеспечивают защиту информации при условии соблюдения требований эксплуатационно-технической документации на СКЗИ и требований действующих нормативных правовых документов в области реализации и эксплуатации СКЗИ;

– для обеспечения безопасности персональных данных при их обработке в информационной системе должны использоваться СКЗИ, прошедшие в установленном порядке процедуру оценки соответствия.

Перечень СКЗИ, сертифицированных ФСБ России, опубликован на официальном сайте Центра по лицензированию, сертификации и защите государственной тайны ФСБ России (www.clsz.fsb.ru). Дополнительную информацию о конкретных средствах защиты информации рекомендуется получать непосредственно у разработчиков или производителей этих средств и, при необходимости, у специализированных организаций, проводивших тематические исследования этих средств.

В случае отсутствия прошедших в установленном порядке процедуру оценки соответствия СКЗИ, функционально пригодных для обеспечения

безопасности персональных данных при их обработке в конкретной информационной системе, на этапе аванпроекта или эскизного (эскизно-технического) проекта разработчиком информационной системы с участием оператора (уполномоченного лица) и предполагаемого разработчика СКЗИ готовится обоснование целесообразности разработки нового типа СКЗИ и определяются требования к его функциональным свойствам.

Решение о разработке нового типа СКЗИ может быть принято оператором в инициативном порядке в независимости от наличия СКЗИ, функционально пригодных для обеспечения безопасности персональных данных при их обработке в конкретной информационной системы. Разработка нового типа СКЗИ осуществляется в соответствии с Положением о разработке, производстве, реализации и эксплуатации шифровальных (криптографических) средств защиты информации, утвержденным приказом ФСБ России от 9 февраля 2005 г. № 66 (далее – Положение ПКЗ-2005);

– СКЗИ являются как средством защиты персональных данных, так и объектом защиты.

В случае, если информационная система является государственной, муниципальной или информационной системой, в которой обрабатывается информация ограниченного доступа (за исключением информации, содержащей персональные данные или сведения, составляющие государственную тайну) к возможным сценариям, когда угрозы могут быть нейтрализованы с помощью СКЗИ, относятся:

- передача информации ограниченного доступа по каналам связи, не защищенным от перехвата нарушителем передаваемой по ним информации или от несанкционированных воздействий на эту информацию;

- выход каналов связи за пределы контролируемой зоны.

При этом необходимо учитывать следующее:

1. Согласно пункту 4 статьи 16 Федерального закона от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации» обладатель информации и оператор информационной системы обязаны обеспечить предотвращение несанкционированного доступа к информации и (или) передачи ее лицам, не имеющим права на доступ к информации.

2. Согласно подпункту 5.8.5 пункта 5.8 Специальных требований и рекомендаций по технической защите конфиденциальной информации (СТР-К), утвержденных приказом Гостехкомиссии России от 30.08.2002 № 282 если каналы связи выходят за пределы КЗ, необходимо использовать защищенные каналы связи, защищенные волоконно-оптические линии связи либо сертифицированные криптографические средства защиты.

3. Согласно Приложению № 2 к Требованиям о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах, утверждены приказом ФСТЭК России №17 от 11.02.2013, для выполнения меры ЗИО.3 оператором должна быть обеспечена защита информации от раскрытия, модификации и навязывания (ввода ложной информации) при ее передаче (подготовке к передаче) по каналам связи, имеющим выход за пределы КЗ.

4. Согласно Методических рекомендаций ФСБ России № 149/7/2/6-432 от 31.03.2015 решение о необходимости криптографической защиты может быть принято конкретным оператором.

Таким образом, исходя из вида обрабатываемой информации в информационной системе и типа самой информационной системы, необходимо выбрать направление обоснования использования криптографических средств защиты информации.

11.2. Подраздел «Определение актуальности угроз, нейтрализуемых только с помощью СКЗИ»

В случае, если для информационных систем, эксплуатируемых при осуществлении соответствующих видов деятельности, угрозы, которые могут быть нейтрализованы только с помощью СКЗИ, неактуальны, изложенные в настоящем разделе угрозы могут не учитываться при разработке модели угроз.

Изложенные в настоящем разделе угрозы в обязательном порядке должны быть учтены при разработке модели угроз в случае, если угрозы, которые могут быть нейтрализованы только с помощью СКЗИ, актуальны.

При этом в описании информационных систем необходимо указывать:

- меры по разграничению доступа в помещения, в которых размещены ресурсы информационной системы, имеющие отношение к криптографической защите;
- информационные технологии, базы данных, технические средства, программное обеспечение, используемые в каждой подсистеме информационной системы или в информационной системе в целом для обработки информации и имеющие отношение к криптографической защите;
- отчуждаемые носители защищаемой информации, используемые в каждой подсистеме информационной системы или в информационной системе в целом, для которых несанкционированный доступ к хранимой на них информации не может быть исключен без использования криптографических методов и способов;
- область применения СКЗИ в информационной системе и цели применения СКЗИ в информационной системе.

В случае, если угрозы, которые могут быть нейтрализованы только с помощью СКЗИ, актуальны или принято решение об использовании СКЗИ для

обеспечения безопасности информации вне зависимости от актуальности таких угроз, помимо исходных данных об информационных системах необходимо описать:

- объекты защиты и актуальные характеристики безопасности объектов защиты угрозы;

- классификация и характеристики нарушителей, а также их возможностей по реализации атак;

- источники атак.

К объектам защиты, в данном случае, кроме информации, относятся:

- СКЗИ;

- среда функционирования СКЗИ (далее - СФ);

- информация, относящаяся к криптографической защите, включая ключевую, парольную и аутентифицирующую информацию СКЗИ;

- документы, дела, журналы, картотеки, издания, технические документы, видео-, кино- и фотоматериалы, рабочие материалы и т.п., в которых отражена защищаемая информация, относящаяся к информационным системам и их криптографической защите, включая документацию на СКЗИ и на технические и программные компоненты СФ;

- носители защищаемой информации, используемые в информационной системе в процессе криптографической защиты, носители ключевой, парольной и аутентифицирующей информации СКЗИ и порядок доступа к ним;

- используемые информационной системой каналы (линии) связи, включая кабельные системы;

– помещения, в которых находятся ресурсы информационной системы, имеющие отношение к криптографической защите информации.

Описание объектов защиты должно отражать специфику информационной системы.

При описании источников атак определяются **категории физических лиц, имеющих право постоянного или разового доступа в контролируемую зону информационной системы.**

К отдельной категории относятся привилегированные пользователи информационной системы (члены группы администраторов), которые назначаются из числа доверенных лиц и осуществляют техническое обслуживание технических и программных средств СКЗИ и СФ, включая их настройку, конфигурирование и распределение ключевой документации между непривилегированными пользователями.

Определяется возможность или невозможность доступа лиц каждой категории к объектам защиты.

Кроме того, определяется и обосновывается перечень категорий лиц, которые не рассматриваются в качестве потенциальных источников атак, перечень категорий лиц, которые рассматриваются в качестве потенциальных источников атак, а также констатируется наличие внешних источников атак (без их характеристики) и возможность или невозможность доступа внешних источников атак к объектам защиты.

На основании исходных данных об информационных системах, объектах защиты и источниках атак в соответствии с Методическими рекомендациями ФСБ России № 149/7/2/6-432 от 31.03.2015 заполняется Таблица № 7 об обобщенных возможностях источников атак.

Таблица 7 - Обобщенные возможности источников атак

№	Обобщенные возможности источников атак	Да/нет
---	--	--------

1	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак только за пределами контролируемой зоны	
2	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак в пределах контролируемой зоны, но без физического доступа к аппаратным средствам (далее – АС), на которых реализованы СКЗИ и среда их функционирования	
3	Возможность самостоятельно осуществлять создание способов атак, подготовку и проведение атак в пределах контролируемой зоны с физическим доступом к АС, на которых реализованы СКЗИ и среда их функционирования	
4	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области анализа сигналов линейной передачи и сигналов побочного электромагнитного излучения и наводок СКЗИ)	
5	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области использования для реализации атак недокументированных возможностей прикладного программного обеспечения)	
6	Возможность привлекать специалистов, имеющих опыт разработки и анализа СКЗИ (включая специалистов в области использования для реализации атак недокументированных возможностей аппаратного и программного компонентов среды функционирования СКЗИ).	

При этом заполнение пунктов 4, 5 и 6 Таблицы № 9 должно осуществляться с учетом объема и содержания обрабатываемой в информационных системах информации, а в случае обработки в информационной системе персональных данных необходимо учитывать и результаты произведенной (во исполнение пункта 5 части 1 статьи 18 Федерального закона от 27 июля 2006 г. № 152-ФЗ «О персональных данных») оценки возможного вреда субъекту персональных данных.

Реализация угроз безопасности информации, обрабатываемых в информационных системах, определяется возможностями источников атак.

Таким образом, актуальность использования возможностей источников атак определяет наличие соответствующих актуальных угроз.

В зависимости от положительных ответов в Таблице № 7 следует заполнить Таблицу № 8 по следующим правилам:

1) в случае, если выбрана только обобщенная возможность № 1, то в Таблице № 8 необходимо привести обоснование признания угроз 1.1-4.3 неактуальными.

При обосновании неактуальности угроз следует приводить перечень организационно-технических мер, реализация которых позволяет нейтрализовать такие угрозы, или особенности функционирования и организации эксплуатации информационной системы, делающие такие угрозы неактуальными.

2) в случае, если в Таблице № 7 максимально выбранная обобщенная возможность не выше № 2, то в Таблице № 8 обязательно актуальна хотя бы одна из угроз 1.1-1.4, а также необходимо привести обоснование признания угроз 2.1-4.3 неактуальными.

3) в случае, если в Таблице № 7 максимально выбранная обобщенная возможность не выше № 3, то в Таблице № 8 обязательно актуальна хотя бы одна из угроз 1.1-2.2, а также необходимо привести обоснование признания угроз 3.1-4.3 неактуальными.

4) в случае, если в Таблице № 7 максимально выбранная обобщенная возможность не выше № 5, то в Таблице № 8 обязательно актуальна хотя бы одна из угроз 1.1-3.3, а также необходимо привести обоснование признания угроз 4.1-4.3 неактуальными.

5) в случае, если в Таблице № 7 выбрана обобщенная возможность № 6, то заполнять Таблицу № 8 нет необходимости.

Таблица 8

№	Уточненные возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование отсутствия
1.1	проведение атаки при нахождении в пределах контролируемой зоны		
1.2	проведение атак на этапе эксплуатации СКЗИ на следующие объекты: - документацию на СКЗИ и компоненты СФ; - помещения, в которых находится совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем (далее - СВТ), на которых реализованы СКЗИ и СФ		
1.3	получение в рамках предоставленных полномочий, а также в результате наблюдений следующей информации: - сведений о физических мерах защиты объектов, в которых размещены ресурсы информационной системы; - сведений о мерах по обеспечению контролируемой зоны объектов, в которых размещены ресурсы информационной системы;		

№	Уточненные возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование отсутствия
	- сведений о мерах по разграничению доступа в помещения, в которых находятся СВТ, на которых реализованы СКЗИ и СФ		
1.4	использование штатных средств информационной системы, ограниченное мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий		
2.1	физический доступ к СВТ, на которых реализованы СКЗИ и СФ		
2.2	возможность воздействовать на аппаратные компоненты СКЗИ и СФ, ограниченная мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий.		
3.1	создание способов, подготовка и проведение атак с привлечением специалистов в области анализа сигналов, сопровождающих функционирование СКЗИ и СФ, и в области использования для реализации атак недокументированных (недекларированных) возможностей прикладного ПО		
3.2	проведение лабораторных исследований СКЗИ, используемых вне контролируемой зоны, ограниченное мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на		

№	Уточненные возможности нарушителей и направления атак (соответствующие актуальные угрозы)	Актуальность использования (применения) для построения и реализации атак	Обоснование отсутствия
	предотвращение и пресечение несанкционированных действий		
3.3	проведение работ по созданию способов и средств атак в научно-исследовательских центрах, специализирующихся в области разработки и анализа СКЗИ и СФ, в том числе с использованием исходных текстов входящего в СФ прикладного ПО, непосредственно использующего вызовы программных функций СКЗИ.		
4.1	создание способов, подготовка и проведение атак с привлечением специалистов в области использования для реализации атак недокументированных (недекларированных) возможностей системного ПО		
4.2	возможность располагать сведениями, содержащимися в конструкторской документации на аппаратные и программные компоненты СФ		
4.3	возможность воздействовать на любые компоненты СКЗИ и СФ		

В случае если по результатам заполнения Таблицы № 8 выявляется отсутствие организационно-технических мер в рассматриваемой информационной системе, реализация которых позволяет нейтрализовать рассматриваемую угрозу, или отсутствует обоснование отсутствия такой угрозы в связи с особенностями функционирования информационной системы, то такая угроза признается актуальной. В таком случае следует

пересмотреть выбор обобщенных возможностей в Таблице № 9 и повторить заполнение Таблицы № 10 с учетом выбора новых обобщенных возможностей.

В соответствии с Приказом ФСБ России от 10 июля 2014 г. № 378 «Об утверждении Состав и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищенности» исходя из полученных сведений о видах нарушителей и их возможностях, о типах актуальных угроз и уровне защищенности персональных данных, принимается решение о классе используемых СКЗИ в информационной системе.

Обобщенные требования к классам СКЗИ приведены в таблице 9.

Таблица 9. Обобщенные требования к классам СКЗИ

Уровень защищенности	Класс СКЗИ		
	Актуальные угрозы 1 типа	Актуальные угрозы 2 типа	Актуальные угрозы 3 типа
1	КА и выше	КВ и выше	-
2	КА и выше	КВ и выше	КС1 и выше
3	-	КВ и выше	КС1 и выше
4	-	-	

При этом необходимо учитывать следующее:

1. **СКЗИ класса КС1** применяются для нейтрализации атак, при создании способов, подготовке и проведении которых используются возможности из числа следующих:

а) создание способов, подготовка и проведение атак без привлечения специалистов в области разработки и анализа СКЗИ;

б) создание способов, подготовка и проведение атак на различных этапах жизненного цикла СКЗИ;

в) проведение атаки, находясь вне пространства, в пределах которого осуществляется контроль за пребыванием и действиями лиц и (или) транспортных средств (далее - контролируемая зона);

г) проведение на этапах разработки (модернизации), производства, хранения, транспортировки СКЗИ и этапе ввода в эксплуатацию СКЗИ (пусконаладочные работы) следующих атак:

- внесение несанкционированных изменений в СКЗИ и (или) в компоненты аппаратных и программных средств, совместно с которыми штатно функционируют СКЗИ и в совокупности представляющие среду функционирования СКЗИ (далее - СФ), которые способны повлиять на выполнение предъявляемых к СКЗИ требований, в том числе с использованием вредоносных программ;

- внесение несанкционированных изменений в документацию на СКЗИ и компоненты СФ;

д) проведение атак на этапе эксплуатации СКЗИ на:

- персональные данные;
- ключевую, аутентифицирующую и парольную информацию СКЗИ;

- программные компоненты СКЗИ;
- аппаратные компоненты СКЗИ;
- программные компоненты СФ, включая программное обеспечение BIOS;

- аппаратные компоненты СФ;
- данные, передаваемые по каналам связи;

- иные объекты, которые установлены при формировании совокупности предположений о возможностях, которые могут использоваться при создании способов, подготовке и проведении атак с учетом применяемых в информационной системе информационных технологий, аппаратных средств (далее - АС) и программного обеспечения (далее - ПО);

е) получение из находящихся в свободном доступе источников (включая информационно-телекоммуникационные сети, доступ к которым не ограничен определенным кругом лиц, в том числе информационно-телекоммуникационную сеть "Интернет") информации об информационной системе, в которой используется СКЗИ. При этом может быть получена следующая информация:

- общие сведения об информационной системе, в которой используется СКЗИ (назначение, состав, оператор, объекты, в которых размещены ресурсы информационной системы);

- сведения об информационных технологиях, базах данных, АС, ПО, используемых в информационной системе совместно с СКЗИ, за исключением сведений, содержащихся только в конструкторской документации на информационные технологии, базы данных, АС, ПО, используемые в информационной системе совместно с СКЗИ;

- содержание конструкторской документации на СКЗИ;

- содержание находящейся в свободном доступе документации на аппаратные и программные компоненты СКЗИ и СФ;

- общие сведения о защищаемой информации, используемой в процессе эксплуатации СКЗИ;

- сведения о каналах связи, по которым передаются защищаемые СКЗИ персональные данные (далее - канал связи);

- все возможные данные, передаваемые в открытом виде по каналам связи, не защищенным от несанкционированного доступа к информации организационными и техническими мерами;

- сведения обо всех проявляющихся в каналах связи, не защищенных от несанкционированного доступа к информации организационными и техническими мерами, нарушениях правил эксплуатации СКЗИ и СФ;

- сведения обо всех проявляющихся в каналах связи, не защищенных от несанкционированного доступа к информации организационными и техническими мерами, неисправностях и сбоях аппаратных компонентов СКЗИ и СФ;

- сведения, получаемые в результате анализа любых сигналов от аппаратных компонентов СКЗИ и СФ;

ж) применение:

- находящихся в свободном доступе или используемых за пределами контролируемой зоны АС и ПО, включая аппаратные и программные компоненты СКЗИ и СФ;

- специально разработанных АС и ПО;

з) использование на этапе эксплуатации в качестве среды переноса от субъекта к объекту (от объекта к субъекту) атаки действий, осуществляемых при подготовке и (или) проведении атаки:

- каналов связи, не защищенных от несанкционированного доступа к информации организационными и техническими мерами;

- каналов распространения сигналов, сопровождающих функционирование СКЗИ и СФ;

и) проведение на этапе эксплуатации атаки из информационно-телекоммуникационных сетей, доступ к которым не ограничен определенным кругом лиц, если информационные системы, в которых используются СКЗИ, имеют выход в эти сети;

к) использование на этапе эксплуатации находящихся за пределами контролируемой зоны АС и ПО из состава средств информационной системы, применяемых на местах эксплуатации СКЗИ (далее - штатные средства).

2. СКЗИ класса КС2 применяются для нейтрализации атак, при создании способов, подготовке и проведении которых используются возможности из числа перечисленных для СКЗИ класса КС1 и не менее одной из следующих дополнительных возможностей:

- а) проведение атаки при нахождении в пределах контролируемой зоны;
- б) проведение атак на этапе эксплуатации СКЗИ на следующие объекты:
 - документацию на СКЗИ и компоненты СФ;
 - помещения, в которых находится совокупность программных и технических элементов систем обработки данных, способных функционировать самостоятельно или в составе других систем (далее - СВТ), на которых реализованы СКЗИ и СФ;
- в) получение в рамках предоставленных полномочий, а также в результате наблюдений следующей информации:
 - сведений о физических мерах защиты объектов, в которых размещены ресурсы информационной системы;
 - сведений о мерах по обеспечению контролируемой зоны объектов, в которых размещены ресурсы информационной системы;
 - сведений о мерах по разграничению доступа в Помещения, в которых находятся СВТ, на которых реализованы СКЗИ и СФ;
- г) использование штатных средств, ограниченное мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий.

3. СКЗИ класса КС3 применяются для нейтрализации атак, при создании способов, подготовке и проведении которых используются возможности из

числа перечисленных для СКЗИ классов КС1 и КС2 и не менее одной из следующих дополнительных возможностей:

- а) физический доступ к СВТ, на которых реализованы СКЗИ и СФ;
- б) возможность располагать аппаратными компонентами СКЗИ и СФ, ограниченная мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий.

4. **СКЗИ класса КВ** применяются для нейтрализации атак, при создании способов, подготовке и проведении которых используются возможности из числа перечисленных для СКЗИ классов КС1, КС2 и КС3 и не менее одной из следующих дополнительных возможностей:

- а) создание способов, подготовка и проведение атак с привлечением специалистов в области анализа сигналов, сопровождающих функционирование СКЗИ и СФ, и в области использования для реализации атак недокументированных (недекларированных) возможностей прикладного ПО;

- б) проведение лабораторных исследований СКЗИ, используемых вне контролируемой зоны, ограниченное мерами, реализованными в информационной системе, в которой используется СКЗИ, и направленными на предотвращение и пресечение несанкционированных действий;

- в) проведение работ по созданию способов и средств атак в научно-исследовательских центрах, специализирующихся в области разработки и анализа СКЗИ и СФ, в том числе с использованием исходных текстов входящего в СФ прикладного ПО, непосредственно использующего вызовы программных функций СКЗИ.

5. **СКЗИ класса КА** применяются для нейтрализации атак, при создании способов, подготовке и проведении которых используются возможности из

числа перечисленные для СКЗИ классов КС1, КС2, КС3 и КВ и не менее одной из следующих дополнительных возможностей:

а) создание способов, подготовка и проведение атак с привлечением специалистов в области использования для реализации атак недокументированных (недекларированных) возможностей системного ПО;

б) возможность располагать сведениями, содержащимися в конструкторской документации на аппаратные и программные компоненты СФ;

в) возможность располагать всеми аппаратными компонентами СКЗИ и СФ.[7]

12. Раздел «Выводы»

Раздел «Выводы» должен содержать краткое резюме проведенной работе по выявлению актуальных угроз безопасности информации, обрабатываемой в информационной системе.

УЧЕБНЫЙ ЦЕНТР "РЦБ" Г. РЯЗАНЬ